

Detección de amenaza interna centrada en el humano: Integración de análisis de *logs* corporativos y perfilado conductual (M4)



Antonio Barrera Mora

Área 2: Natural Language Processing,
Cibersecurity and Visual Analytics
(A2. NPL&VA)

Máster en Ciencia de Datos

Director del TF:

Blas Torregrosa García

Directora de la PRA:

Esther Ibáñez

12 de mayo de 2026

**Universitat Oberta
de Catalunya**



Esta obra esta sujeta a una licencia de Reconocimiento-NoComercial
<https://creativecommons.org/licenses/by-nc/3.0/es/>

Ficha Del Trabajo Final

Título del trabajo:	Detección de amenaza interna centrada en el humano: Integración de análisis de <i>logs</i> corporativos y perfilado conductual (M4)
Nombre del autor/a:	Antonio Barrera Mora
Director del TF:	Blas Torregrosa García
Directora de la PRA:	Esther Ibáñez
Fecha de entrega:	12 de mayo de 2026
Titulación o programa:	Máster en Ciencia de Datos
Área del trabajo final:	Área 2: Natural Language Processing, Cybersecurity and Visual Analytics (A2. NPL&VA)
Idioma del trabajo:	Castellano
Palabras clave:	Insider Threat, UEBA, NLP, Machine Learning, Criminología Corporativa, Dataset CERT

Resumen del trabajo

La detección de la Amenaza Interna (*Insider Threat*) sigue siendo uno de los mayores retos en la ciberseguridad corporativa. Las soluciones tradicionales basadas en reglas técnicas a menudo fracasan al identificar a empleados maliciosos, pues estos poseen credenciales legítimas. En esta propuesta planteamos un enfoque híbrido de Detección de Amenazas Internas Centrado en el Humano. Empleando el *dataset* CERT r4.2, el proyecto combinará la extracción de características técnicas (*logs* de acceso y navegación web) con el análisis de indicadores conductuales extraídos mediante Procesamiento de Lenguaje Natural (NLP) aplicado a comunicaciones internas. Posteriormente, entrenaremos modelos de aprendizaje automático no supervisado (e.g.: *Isolation Forest*) para detectar anomalías que representen un riesgo real. Con esto habremos demostrado que la integración de la criminología, la psicología y la ciencia de datos permite una mitigación proactiva y precisa frente a la amenaza interna.

Abstract

Detecting the Insider Threat remains one of the greatest challenges in corporate cybersecurity. Traditional solutions based on technical rules often fail to identify malicious employees, as they possess legitimate credentials. This proposal presents a hybrid approach for Human-Centric Insider Threat Detection. Using the CERT r4.2 dataset, the project will combine the extraction of technical features (access and web navigation logs) with the analysis of behavioral indicators extracted through Natural Language Processing (NLP) applied to internal communications. Subsequently, unsupervised machine learning models (e.g., Isolation Forest) will be trained to detect anomalies representing actual risk, demonstrating that the integration of criminology, psychology, and data science enables proactive and accurate mitigation against insider threats.

Índice general

1. Introducción	9
1.1. Contexto y justificación del trabajo	9
1.2. Motivación personal	9
1.3. Objetivos del trabajo	10
1.4. Preguntas de investigación e hipótesis	10
1.5. Impacto en sostenibilidad, ético-social y de diversidad	11
1.6. Enfoque y método seguido	12
1.7. Planificación del trabajo	12
1.7.1. Gestión de Riesgos:	13
1.8. Declaración sobre el uso de inteligencia artificial generativa	13
2. Estado del arte	14
2.1. Criminología corporativa y la psicología del atacante interno	14
2.2. Análisis de Comportamiento de Usuarios y Entidades (UEBA)	15
2.3. Procesamiento de Lenguaje Natural (NLP) en ciberseguridad	16
2.4. Justificación y aportación diferencial de la propuesta	16
3. Materiales y métodos	18
3.1. Diseño y desarrollo del trabajo	18
3.2. Metodología y toma de decisiones	19
3.2.1. Selección y justificación de hiperparámetros	19
3.3. Limitaciones del <i>dataset</i> y validez ecológica	20
3.4. Productos obtenidos	21
4. Resultados	23
5. Discusión	27
5.1. El sentimiento como confirmador, no como detonador (PIE 1)	27
5.2. Limitaciones del AUC como métrica principal (PIE 2)	27
5.3. Complementariedad algorítmica y sistema de ensamblaje (PIE 3)	28
5.4. Validación XAI del modelo criminológico CPIR (PIE 4)	28
5.5. Marco ético, legal y protocolo de actuación	29
5.6. El rol del <i>Big Five</i> en el modelo	30
5.7. Consideraciones éticas y legales del uso de psicometría organizacional	30

6. Conclusiones y trabajos futuros	32
6.1. Conclusiones	32
6.2. Logro de los objetivos	33
6.3. Análisis de planificación y metodología	33
6.4. Impactos éticos, sociales y normativos	33
6.5. Líneas de futuro	33
7. Glosario	37
8. Bibliografía	45

Índice de figuras

4.1. Curva ROC del Autoencoder ($AUC = 0.551$). La distancia respecto al AUC del <i>Isolation Forest</i> (0.629) ilustra empíricamente el coste que supone para la métrica global la concentración del error de reconstrucción en el umbral crítico superior.	24
4.2. <i>Waterfall</i> SHAP del usuario MPM0220. Las barras en rojo indican variables que empujan el <i>Anomaly Score</i> hacia mayor riesgo, mientras que las azules lo anclan hacia la normalidad. La variable de mayor contribución es la actividad fuera de horario, seguida de la hiperactividad de inicio de sesión y el uso de dispositivos USB.	26

Índice de cuadros

4.1. Descomposición SHAP del evento crítico del usuario confirmado MPM0220 (2010-10-04). El valor base del modelo es $E[f(X)] = 12,306$; la predicción final resulta $f(x) = 4,369$	25
--	----

Capítulo 1

Introducción

El coste de los incidentes provocados por amenazas internas ha crecido exponencialmente en los últimos años. Este incremento ha ido afectando tanto a la propiedad intelectual como a la reputación y cumplimiento normativo de las organizaciones. Los enfoques clásicos de ciberseguridad centran su trabajo en el perímetro (ataques externos) o en la auditoría puramente técnica (monitorización de direcciones IP, puertos, etc.). Sin embargo, un atacante interno (un saboteador o el personal que exfiltra datos por descontento o coacción, por citar algunos arquetipos), al tratarse de seres humanos suelen manifestar cambios conductuales y psicológicos detectables antes de cometer el acto técnico-delictivo. Finalmente, cabe destacar que la necesidad de evolucionar hacia modelos conductuales no solo responde a un desafío técnico, sino a un impacto financiero crítico: según el informe *Cost of Insider Threats* (BobSulli, 2023), el coste medio anual para las organizaciones derivado de incidentes internos asciende a 15,4 millones de dólares, habiendo aumentado drásticamente ante la ineficacia de los sistemas puramente volumétricos.

1.1. Contexto y justificación del trabajo

La relevancia de este trabajo radica en su enfoque multidisciplinar, conocido en el sector como **Análisis del Comportamiento de Usuarios y Entidades** (UEBA, por sus siglas en inglés). En lugar de investigar únicamente firmas de código malicioso, este proyecto pretende parametrizar factores de riesgo, como la frustración o la desviación brusca de la rutina operativa. Es decir, buscamos comportamientos humanos que delaten al perpetrador. Justificar esta correlación clínico-técnica mediante algoritmos de *Machine Learning* aporta una solución analítica innovadora al mercado corporativo. Este enfoque permitiría a los departamentos de seguridad y recursos humanos adelantarse a la ruta crítica del incidente.

1.2. Motivación personal

Este abordaje nace de una trayectoria profesional continua de más de 20 años que aún a dos ámbitos tradicionalmente separados: por un lado, una extensa experiencia operativa en seguridad e infraestructuras de TI institucionales; y, por otro, la formación académica y práctica como Psicólogo Clínico y Criminólogo.

A lo largo del ejercicio profesional, hemos observado y corroborado cómo la seguridad técnica resulta insuficiente cuando ignora el factor humano, del mismo modo que la psicología forense carece frecuentemente de herramientas computacionales a gran escala para auditar riesgos en entornos corporativos complejos. Este Trabajo Final de Máster representa la oportunidad idónea para unificar estas disciplinas. El objetivo a nivel de desarrollo de carrera es consolidar un marco de auditoría de riesgos ciber-conductuales aplicable al sector de la consultoría estratégica de seguridad, aportando un valor diferencial basado en la conjunción de los conocimientos adquiridos en el Máster de Ciencia de Datos y el bagaje clínico previo.

1.3. Objetivos del trabajo

Objetivo Principal:

Desarrollar un **modelo analítico de detección de anomalías** para identificar amenazas internas corporativas, integrando variables técnicas de sistemas de información con indicadores conductuales extraídos mediante el análisis de sentimientos de las comunicaciones organizacionales.

Objetivos Secundarios:

- Preprocesar y estructurar datos heterogéneos y multivariantes del *dataset* CERT r4.2 (*logon.csv*, *device.csv*, *http.csv*, *email.csv*) para construir una **matriz de perfiles de actividad por usuario**.
- Aplicar técnicas de Procesamiento de Lenguaje Natural (NLP). Específicamente, emplearemos la extracción de polaridad y subjetividad sobre los metadatos de correos electrónicos para generar **características psicológicas cuantificables**.
- Entrenar y **comparar algoritmos de detección de anomalías no supervisados** (como *Isolation Forest* o *One-Class SVM*) abordando metodológicamente el problema del desbalanceo extremo de clases característico de los incidentes de ciberseguridad.
- **Evaluar el rendimiento del modelo** a través de métricas y el análisis forense de casos de estudio específicos (simulados en la *ground truth* del *dataset*), demostrando su capacidad predictiva en fases tempranas del ciclo de ataque.

1.4. Preguntas de investigación e hipótesis

Para operacionalizar el objetivo general del proyecto y estructurar el proceso de validación empírica, la presente investigación formula las siguientes preguntas de investigación:

Pregunta de Investigación General (PIG):

¿Es posible anticipar y detectar incidentes de amenaza interna (Insider Threat) en un entorno corporativo mediante la aplicación de modelos de aprendizaje automático no supervisado sobre una matriz conductual que integre volumetría técnica y métricas de deriva psicológica?

Preguntas de Investigación Específicas (PIE):

- **PIE 1 (Psicología y deriva conductual):** ¿En qué medida la cuantificación de la deriva conductual (calculada a través del análisis de sentimiento y el *Z-Score* personalizado de las comunicaciones) mejora la capacidad predictiva de las anomalías frente a un enfoque puramente volumétrico y técnico?
- **PIE 2 (Desbalanceo extremo):** Ante la naturaleza inherentemente escasa del fraude interno, ¿qué grado de eficacia medido en Tasa de Captura (*Recall*) pueden alcanzar algoritmos no supervisados de detección de anomalías sin recurrir a técnicas de sobremuestreo sintético que distorsionen la estructura real del comportamiento organizacional?
- **PIE 3 (Sistema de votación por ensamblaje):** ¿De qué manera la combinación de paradigmas algorítmicos distintos (modelos de partición espacial (*Isolation Forest*) frente a modelos de aprendizaje profundo (*Autoencoders*)) contribuye a maximizar la detección de saboteadores sin incrementar la fatiga de alertas operativa?
- **PIE 4 (Explicabilidad y Aplicabilidad Criminológica):** ¿Es posible traducir las decisiones matemáticas de los modelos predictivos en evidencias operativas y trazables mediante técnicas de Inteligencia Artificial Explicable (XAI), de forma que validen las premisas del modelo criminológico *Critical Path to Insider Risk* (CPIR)?

La hipótesis de trabajo subyacente es que la integración de señales heterogéneas (técnicas y psicológicas) en una matriz conductual unificada producirá un sistema de detección con mayor capacidad de anticipación que cualquiera de los enfoques unidimensionales por separado, manteniendo una tasa de alertas operativamente asumible para los equipos de seguridad.

1.5. Impacto en sostenibilidad, ético-social y de diversidad

El presente Trabajo Final se alinea de manera fundamental con el Objetivo de Desarrollo Sostenible (ODS) 9 (Industria, Innovación e Infraestructura) mediante el desarrollo de tecnologías que fortalecen la ciber-resiliencia corporativa. También con el ODS 16 (Paz, Justicia e Instituciones Sólidas) al proporcionar mecanismos técnicos para mitigar el fraude interno, el sabotaje y el robo de propiedad intelectual.

Desde la dimensión ética y de diversidad, el modelo de detección propuesto se fundamenta en los principios de **neutralidad algorítmica y privacidad desde el diseño**. Al basar la evaluación del riesgo estrictamente en variables operativas de TI (horarios de conexión, frecuencias de transferencia de datos) y en el procesamiento automatizado del lenguaje natural (NLP) —el cual opera ciego ante metadatos demográficos—, el sistema previene activamente la introducción de sesgos cognitivos o discriminatorios (por género, raza, edad u origen) que frecuentemente contaminan la evaluación humana tradicional en el ámbito corporativo o de recursos humanos. Por tanto, **el impacto social previsto es netamente positivo**, dotando a las organizaciones de un marco de auditoría justo, objetivo y basado exclusivamente en la evidencia conductual-técnica del usuario.

1.6. Enfoque y método seguido

El proyecto emplearemos una adaptación del ciclo de vida estándar para proyectos de ciencia de datos (CRISP-DM), integrando como capa inicial un análisis basado en teorías criminológicas (como la ruta crítica del *Insider Threat*). La estrategia metodológica se divide en las siguientes fases:

- **Fase de Comprensión:** Revisión del marco teórico para fundamentar la selección de variables operativas y psicológicas susceptibles de ser vectorizadas.
- **Fase de Preparación de Datos:** Ingesta del *dataset* masivo (CERT r4.2) empleando ecosistemas de *Python* (*Pandas/NumPy*). Se ejecutará la limpieza, normalización y agregación en ventanas temporales para unificar *logs* técnicos con datos textuales no estructurados.
- **Fase de Ingeniería de Características (*Feature Engineering*):** Extracción de métricas de sentimiento mediante librerías de NLP (NLTK/VADER) y derivación de variables complejas (e.g. desviación estándar de horarios de conexión).
- **Fase de Modelado:** Implementación de algoritmos de detección de valores atípicos (*outliers*) no supervisados, debido a la naturaleza subrepresentada de la clase positiva (atacante) en escenarios reales.
- **Fase de Evaluación:** Validación del modelo contrastando los resultados con la matriz de incidentes inyectada en el *dataset*, utilizando curvas Precisión-*Recall* y análisis forense descriptivo de los falsos positivos/negativos.

Consideramos esta metodología la óptima pues emula el escenario operativo de un analista de seguridad real, priorizando la fiabilidad y la explicabilidad (clave para entornos empresariales) sobre la aplicación de técnicas de *Deep Learning* de tipo caja negra” que dificultan la auditoría conductual.

1.7. Planificación del trabajo

La planificación temporal se ha diseñado mediante un desglose de tareas asociado a las Pruebas de Evaluación Continua (PEC) requeridas por la asignatura:

- **Hito 1 (PEC 1): Definición del Proyecto (Semanas 1-2).** Finalización: 01/03. Establecimiento del alcance, justificación ética/técnica y validación inicial del entorno de trabajo local en *Python* con los datos en bruto.
- **Hito 2 (PEC 2): Estado del Arte (Semanas 3-5).** Finalización: 22/03. Ejecución de la revisión bibliográfica sistemática sobre UEBA y modelos criminológicos en ciberseguridad.
- **Hito 3 (PEC 3): Implementación y Desarrollo (Semanas 6-12).** Finalización: 10/05. Programación del *pipeline* de datos, aplicación de técnicas de NLP, entrenamiento de los modelos de detección de anomalías y extracción tabular/visual de resultados.

- **Hito 4 (PEC 4): Redacción y Presentación (Semanas 13-15).** Finalización: 02/06. Integración progresiva de los capítulos metodológicos, consolidación de la memoria final y grabación de la presentación audiovisual en formato continuo.
- **Hito 5 (PEC 5): Defensa Pública (Semanas 16-19).** Finalización: 26/06. Revisión de posibles cuestiones planteadas por el tribunal y defensa síncrona/asíncrona del Trabajo Final.

1.7.1. Gestión de Riesgos:

El principal riesgo detectado es la saturación de recursos computacionales locales (RAM) debido a la volumetría del *dataset* (múltiples *gigabytes* en memoria). El plan de mitigación consiste en aplicar técnicas de lectura por lotes (*chunking*) mediante **pandas** o, en caso de persistir el bloqueo, la reducción de la muestra poblacional a un subconjunto aleatorio representativo para la validación del modelo (e.g. 200 usuarios).

1.8. Declaración sobre el uso de inteligencia artificial generativa

El presente trabajo ha hecho uso de herramientas de inteligencia artificial generativa de forma diferenciada según la fase del proyecto:

- **Hasta la entrega de la PEC2/M2 (10 de marzo de 2026):** No se emplearon herramientas de inteligencia artificial generativa en ninguna fase de investigación, redacción o análisis. El documento entregado y evaluado fue elaborado íntegramente por el autor.
- **Durante la PEC3/M3 (desde el 11 de marzo de 2026):** Se ha empleado el modelo de lenguaje **Claude** (Anthropic, 2025) como herramienta de asesoramiento y revisión en las siguientes tareas específicas: (a) verificación de coherencia entre los resultados de los *notebooks* de programación y el texto de la memoria; (b) orientación sobre la estructura y ubicación de secciones en el documento; y (c) revisión crítica del redactado académico de secciones elaboradas por el autor. El diseño metodológico, la implementación del código, el análisis de resultados y la interpretación criminológica y psicológica del trabajo son íntegramente atribuibles al autor. Los textos han sido revisados y validados críticamente antes de su incorporación al documento.

Esta declaración se realiza en cumplimiento de la política académica de integridad de la Universitat Oberta de Catalunya (UOC) sobre el uso ético y transparente de herramientas de inteligencia artificial generativa en trabajos finales de máster.

Capítulo 2

Estado del arte

La detección de la Amenaza Interna (*Insider Threat*) representa uno de los desafíos más asimétricos en el ámbito de la ciberseguridad. A diferencia de los actores externos, en este caso el atacante interno ya posee acceso legítimo a los sistemas de la compañía. Asimismo, se le presume un cierto conocimiento de la arquitectura de defensa y, consecuentemente, disfruta de niveles de confianza o permisos otorgados por la propia organización. Por otro lado, la política de adjudicación y revisión de dichos permisos suele ser poco deliberada o carece de revisiones debidamente planificadas.

Cabe abundar que, muy frecuentemente, se da el caso de no haber estudiado suficientemente el perfil del empleado. Finalmente, las empresas no suelen contemplar la posibilidad de que se produzcan cambios en la relación laboral a lo largo de un proceso diacrónico, especialmente después de los avatares frecuentes en el ciclo vital y profesional del trabajador. Para contextualizar el enfoque híbrido propuesto en este trabajo, en el presente capítulo revisaremos la literatura académica y el estado actual de la industria desde tres ejes convergentes: los modelos teóricos de la criminología corporativa, las soluciones técnicas de análisis de comportamiento (UEBA) y la aplicación del Procesamiento de Lenguaje Natural (NLP) para la inferencia de estados psicológicos de riesgo.

2.1. Criminología corporativa y la psicología del atacante interno

La literatura criminológica ha tratado de explicar reiteradamente la motivación subyacente al fraude y el sabotaje corporativo. El clásico Triángulo del Fraude (Cressey, 1973) establece que el acto delictivo requiere la convergencia de tres factores: la oportunidad (el acceso técnico), la motivación (presiones financieras o agravios) y la racionalización (la justificación cognitiva del acto). Asimismo, en el ámbito de la inteligencia, el acrónimo MICE (*Money, Ideology, Coercion, Ego*) ha servido tradicionalmente para categorizar las motivaciones del espionaje.

Sin embargo, la aproximación más operativa para este Trabajo Final es el *Critical-Pathway Declarative Model* (CPIR) desarrollado por Shaw y Sellers (2015). Este modelo postula que la amenaza interna no es un evento espontáneo, sino el resultado de un proceso progresivo que se inicia con estresores personales o profesionales, evoluciona hacia comportamientos preocupantes

(*concerning behaviors*) y culmina en la acción maliciosa. Diferentes estudios constatan que este periodo de incubación (conocido como deriva conductual o *behavioral drift*) tiene una duración promedio de 73 días antes de la ejecución del ataque.

Desde una perspectiva puramente psicológica, Greitzer y Frincke (2010) subrayan la necesidad imperiosa de incorporar datos psicosociales a las auditorías técnicas, argumentando que el análisis exclusivo de eventos informáticos es ciego a la intención del usuario. En consecuencia, la tecnología por sí sola, carente de contexto humano, resulta insuficiente para anticipar la motivación; es perentorio perfilar la conducta para predecir el riesgo antes de que se materialice en un incidente técnico de gravedad.

2.2. Análisis de Comportamiento de Usuarios y Entidades (UEBA)

Históricamente, la detección de intrusiones se ha fundamentado en sistemas de Gestión de Información y Eventos de Seguridad (SIEM, por sus siglas en inglés), los cuales operan mediante reglas estáticas y heurísticas predefinidas. Sin embargo, como apuntan numerosos autores, estas soluciones perimetrales resultan crónicamente insuficientes frente al atacante interno, en tanto que sus credenciales son legítimas y sus acciones técnicas pueden mimetizarse fácilmente con el flujo de trabajo diario de un empleado o de su propia descripción de puesto (Al-Mhiqani et al., 2020; Yuan & Wu, 2021).

Ante esta limitación, la industria ha pivotado hacia el Análisis de Comportamiento de Usuarios y Entidades (UEBA). Este paradigma abandona la búsqueda de la 'firma del malware' en favor de la creación de una línea base (*baseline*) que parametriza el comportamiento normal o habitual de un individuo (Mladenovic et al., 2024).

Para lograr este perfilado dinámico, la investigación contemporánea se apoya fuertemente en el aprendizaje automático (*Machine Learning*) y, en concreto, en los enfoques no supervisados. La justificación empírica de esta elección radica en la extrema rareza estadística de los incidentes internos: en un entorno corporativo masivo, la clase positiva (el atacante) representa una fracción minúscula de los datos, dificultando el entrenamiento de modelos supervisados tradicionales (Tuor et al., 2017).

En este contexto, algoritmos de detección de anomalías como *Isolation Forest*, Redes Neuronales Auto-codificadoras (*Autoencoders*) o *One-Class SVM*, han demostrado una notable eficacia al identificar desviaciones sutiles en los patrones de conexión o transferencia de archivos. No obstante, la literatura también advierte de un escollo inherente al enfoque puramente técnico: la dependencia exclusiva de los *logs* de red genera altas tasas de falsos positivos (Haq y Alshehri, 2022). Un empleado trabajando de madrugada o descargando una cantidad inusual de datos por exigencias de un proyecto urgente será inexorablemente etiquetado como 'anómalo' por el modelo, saturando al equipo de seguridad con alertas que carecen de contexto clínico o intencional (Wei et al., 2024).

2.3. Procesamiento de Lenguaje Natural (NLP) en ciberseguridad

La brecha explicativa que adolecen los sistemas UEBA estrictamente operacionales ha motivado la integración del Procesamiento de Lenguaje Natural (NLP) como puente hacia la psicología del sujeto (Soh et al., 2019). Retomando el modelo CPIR, si la génesis de la amenaza es un estresor que desencadena un cambio de actitud, las comunicaciones corporativas internas (tales como el correo electrónico) representan el canal más transparente para medir dicha fricción emocional.

Múltiples estudios recientes constatan que el análisis de sentimiento (*Sentiment Analysis*) aplicado a los correos electrónicos mediante diccionarios léxicos (e.g. VADER) o técnicas de incrustación de palabras (*Word Embedding*), permite extraer indicadores psicométricos cuantificables antes de que se produzca la exfiltración técnica (Haq y Alshehri, 2022).

La extracción de métricas como la polaridad (positiva, negativa o neutra) y la subjetividad en las comunicaciones ha sido rigurosamente validada mediante conjuntos de datos sintéticos, siendo el *dataset* CERT (versiones r4.2 o r6.2) el estándar académico de referencia (Asad, s.f.; Glasser y Lindauer, 2013). En estos escenarios controlados, se observa cómo usuarios sometidos a presiones disciplinarias o desencantos laborales reflejan un ‘ensombrecimiento’ (*darkening*) en su lenguaje meses antes de acometer actos de sabotaje informático (Le et al., 2020).

2.4. Justificación y aportación diferencial de la propuesta

No obstante los avances significativos en la ciberseguridad corporativa, la amenaza interna (*Insider Threat*) sigue siendo uno de los desafíos más complejos y costosos para las organizaciones y representa la mayor parte de los incidentes de seguridad críticos (Al-Mhiqani et al., 2020). Mediante una revisión exhaustiva del estado de la cuestión en la actualidad evidenciamos una gran brecha metodológica y conceptual en cómo la industria y la academia abordan este problema: **la desconexión fundamental entre la psicología teórica y la monitorización técnica de sistemas** (Ohu & Jones, 2025).

Por un lado, las herramientas técnicas tradicionales y los sistemas avanzados de Análisis de Comportamiento de Usuarios y Entidades (UEBA) procesan volúmenes masivos de registros de red (*logs*), pero son intrínsecamente ‘ciegos’ al contexto humano y emocional del usuario (Fayyad, 2025). Sin esta dimensión psicosocial, estos sistemas generan una tasa inasumible de falsos positivos y ‘fatiga de alertas’, marcando como amenazas comportamientos que son estadísticamente anómalos pero benignos (Khan & Arshad, 2022).

Por otro lado, la psicología conductual y la criminología corporativa proporcionan marcos teóricos ideales para comprender la motivación del atacante (e.g. el modelo M.I.C.E., el Triángulo del Fraude de Cressey o la ruta crítica del modelo CPIR), pero que normalmente se aplican a posteriori en investigaciones forenses, adoleciendo de una falta de escalabilidad informática para la prevención en tiempo real (Ohu & Jones, 2025).

La aportación diferencial de este Trabajo Final de Máster (TFM) radica precisamente en tender un puente entre estas dos disciplinas aisladas. La propuesta principal consiste en unificar la detección de anomalías estadísticas de red con el Procesamiento de Lenguaje Natural (NLP) aplicado a las comunicaciones corporativas (análisis de sentimiento), superando las limitaciones de los enfoques unidimensionales.

Este enfoque híbrido aportaría, a nuestro entender, tres valores diferenciales clave:

1. **Predicción temprana centrada en la 'Ideación' (Ruta Crítica)**

A diferencia de los sistemas reactivos, que lanzan alertas en el momento en que la exfiltración de datos o el sabotaje ya están en curso, este modelo utilizaría el NLP como un sensor proactivo. La literatura demuestra que los atacantes internos atraviesan una fase de 'deriva conductual' (*behavioral drift*) y disonancia cognitiva observable antes de cometer el delito (Soh et al., 2019; Fayyad, 2025). Al monitorizar la evolución temporal del sentimiento (e.g. un aumento de la hostilidad o la caída en la polaridad positiva en los correos electrónicos), la propuesta permitiría predecir el riesgo en las fases tempranas de predisposición e ideación del modelo CPIR.

2. **Reducción drástica de falsos positivos**

La integración del estado emocional del empleado habilita contextualizar la anomalía técnica. Un pico de actividad nocturna o un volumen inusual de descargas dejará de ser una simple desviación estadística; si se cruza con un lenguaje que denota estrés, frustración o descontento laboral, el sistema valida la alerta técnica con evidencia psicosocial. Este cruce multimodal ha demostrado empíricamente ser la vía más efectiva para reducir los falsos positivos que lastran a los sistemas de seguridad actuales (Fayyad, 2025; Singh et al., 2022).

3. **Una capa forense explicable (XAI) con sentido criminológico**

El uso de algoritmos de *Machine Learning* y *Deep Learning* a menudo presenta el problema de la 'caja negra'. Es decir, el sistema predice un riesgo pero no puede explicar el razonamiento seguido para llegar a semejante conclusión (Nanamou et al., 2024; Fayyad, 2025). La clave de esta propuesta metodológica por lo tanto, es que traduciremos las métricas matemáticas en una narrativa criminológica explicable. No nos limitaremos a clasificar a un usuario como 'anómalo' en un espacio vectorial; aportaremos una capa explicativa que dote de intención a la alerta, permitiendo perfilar a un nivel forense si el riesgo obedece a codicia, venganza o coacción (modelo M.I.C.E.).

En este trabajo no pretendemos simplemente optimizar un clasificador binario, sino transformar un problema puramente técnico en un modelo de inteligencia conductual predictiva. Dotando los *logs* de red de un contexto clínico e intencional, la propuesta ofrecería a los departamentos de seguridad y recursos humanos una herramienta auditable, ética y altamente precisa para intervenir y apoyar al empleado antes de que el riesgo se convierta en un incidente crítico.

Capítulo 3

Materiales y métodos

3.1. Diseño y desarrollo del trabajo

El diseño de la presente investigación se ha estructurado en torno a la validación empírica del modelo criminológico *Critical Path to Insider Risk* (CPIR). Para ello, se desarrolla un sistema de detección analítico capaz de fusionar la volumetría técnica de los usuarios (interacción con sistemas, descargas, horarios, etc.) con su perfilado psicológico dinámico (deriva conductual y afectiva).

El trabajo se desarrolló sobre el conjunto de datos CERT r4.2. Este es una simulación sintética de alta fidelidad que proporciona un entorno controlado con miles de usuarios legítimos y una densidad conocida de atacantes (*insiders*). El desarrollo se dividió en cuatro fases operativas:

1. **Análisis exploratorio** del conjunto de fuentes que componen CERT r4.2 para establecer patrones de referencia, calidad de datos y decisiones metodológicas.
2. **Ingesta y agregación de fuentes heterogéneas** (HTTP, Logon, USB, File, Email, Psychometric y LDAP limitado al periodo más reciente)
3. **Ingeniería de características** con especial énfasis en el Procesamiento de Lenguaje Natural NLP para evaluar el sentimiento de las comunicaciones.
4. **Modelado algorítmico y auditoría forense**. Para prevenir el sobreajuste (*overfitting*), se implementaron dos salvaguardas complementarias: capas de regularización *Dropout* (tasa = 0.2) en el *encoder*. El objetivo era obligar a la red a aprender representaciones fiables y distribuidas en lugar de memorizar el ruido del conjunto de entrenamiento; y una división de validación durante el entrenamiento (`validation_split = 0.1`) que habilitó monitorizar la curva de pérdida sobre datos no vistos y detectar posibles divergencias entre el error de entrenamiento y el de validación. Las curvas de convergencia mostraron una reducción progresiva y coherente de ambas métricas de pérdida a lo largo de las 10 épocas, descartando la presencia de sobreajuste significativo.

3.2. Metodología y toma de decisiones

Dada la naturaleza criminológica del problema, donde la amenaza interna constituye un evento extremadamente anómalo y escaso frente a la masiva actividad corporativa legítima, se descartó el uso de algoritmos de clasificación supervisada.

- **Alternativas consideradas y descartadas:** Se evaluó la posibilidad de emplear técnicas de sobremuestreo (aleatorio, SMOTE y Smote-Nc, ADASYN, etc.) y sus variedades algorítmicas) para equilibrar las clases y aplicar modelos supervisados tradicionales (e.g. *Random Forest*). Sin embargo, se rechazó metodológicamente esta posibilidad ya que la generación de eventos maliciosos sintéticos distorsionaría la realidad clínica y técnica del entorno, invalidando la premisa de aislar comportamientos psicológicos sutiles.
- **Decisión adoptada:** Se optó por un paradigma de aprendizaje automático no supervisado (*Unsupervised Learning*) enfocado en la detección de anomalías. Seleccionamos el algoritmo *Isolation Forest* como modelo base (*baseline*) por eficacia computacional en el aislamiento de *outliers* mediante particiones ortogonales y finalmente, por arquitecturas de aprendizaje profundo (*Autoencoders*) agenciado a la captura de relaciones no lineales complejas entre la psicometría y la actividad técnica.

3.2.1. Selección y justificación de hiperparámetros

Dado el paradigma de aprendizaje no supervisado adoptado, la optimización de hiperparámetros no pudo realizarse mediante los métodos estándar de validación cruzada supervisada (e.g., *Grid Search* o *Random Search* con métricas de clasificación), ya que estos requieren etiquetas de clase durante el proceso de búsqueda, lo que introduciría fuga de datos (*data leakage*) al explotar la *Ground Truth* en el ajuste del modelo.

En su lugar, la selección de hiperparámetros se fundamentó en un **razonamiento operativo explícito**:

- ***Isolation Forest*:** Fijamos `contamination = 0.005` (0.5 %) como reflejo directo de la restricción operativa real de un departamento de Seguridad o RRHH, que difícilmente puede absorber la investigación de más del 0.5 % de la actividad corporativa diaria sin incurrir en fatiga de alertas. El número de estimadores se estableció en `n_estimators = 200`, valor superior al mínimo recomendado por la literatura (100) para garantizar estabilidad en la puntuación de riesgo sobre conjuntos de alta dimensionalidad. Ambas decisiones son, por tanto, decisiones de diseño operativo con justificación criminológica y de usabilidad, no el resultado de una optimización ciega sobre una función de pérdida.
- ***Autoencoder*:** La arquitectura de embudo (16-8-4-8-16) fue seleccionada siguiendo las recomendaciones de la literatura para conjuntos de dimensionalidad moderada (11 variables de entrada), garantizando una compresión suficiente en el espacio latente sin subespecificar la capacidad de la red. El número de épocas de entrenamiento (10) fue determinada por inspección visual de las curvas de pérdida de entrenamiento y validación, que mostraron convergencia sin divergencia entre ambas métricas, descartando la presencia de sobreajuste significativo.

Esta estrategia de justificación operativa de hiperparámetros es la práctica habitual en sistemas UEBA desplegados en entornos reales, donde el umbral de alerta no es un parámetro estadístico sino una decisión de gestión de riesgo organizacional (Wei et al., 2024).

Asimismo cabe destacar que para evitar el *Data Leakage* o **fuga de datos** en el cálculo de la deriva psicológica, se implementaron ventanas móviles históricas desplazadas (**shift(1)**). Se buscaba garantizar que el estado emocional del usuario solo se compara con su propio pasado estricto, simulando un entorno de producción real.

Finalmente, se cerró esta subsección agregando una **nota metodológica** sobre la formalización explícita de las preguntas de investigación. Este trabajo de formulación fue llevado a cabo de forma retroactiva durante la PEC3/M3, una vez que los resultados empíricos permitieron acotar con precisión los interrogantes que el proyecto efectivamente responde, aunque la formulación de las mismas preguntas ya fue efectuada de manera tentativa a la hora de acometer el trabajo de la PEC1/M2 y PEC2/M2, momento en el que se decidió no incluirlas hasta poder formularlas precisamente.

3.3. Limitaciones del *dataset* y validez ecológica

La naturaleza sintética del *dataset* CERT r4.2 introduce una limitación estructural que conviene abordar con rigor antes de interpretar los resultados: el mapeo de variables técnicas a parámetros psicológicos compromete la **validez ecológica** del conjunto de datos.

En psicología y metodología de la investigación, la validez ecológica define el **grado en que los resultados obtenidos en un entorno controlado son representativos y generalizables a los comportamientos y situaciones de la vida real** (Sollod et al., 2009; Bronfenbrenner, 1977). No se trata de un atributo binario sino de un continuo: cuanto más artificiales son las condiciones de producción de los datos, menor es la confianza en que las relaciones estadísticas detectadas reflejen dinámicas genuinas del comportamiento humano fuera del entorno simulado.

El CERT r4.2 fue desarrollado por ingenieros de la Universidad *Carnegie Mellon* como un problema de optimización matemática. Los valores asignados a cada dimensión del modelo *Big Five* no provienen de evaluaciones psicométricas reales, sino de *proxies* técnicos: la impuntualidad reiterada en el fichaje de horas de entrada se traduce en un valor bajo en Escrupulosidad (C); el volumen y la red de destinatarios de los correos electrónicos del archivo LDAP se emplea para estimar la Extraversión (E) y así para todas las dimensiones del *Big Five* con base en artilugios técnicos.

El sistema de mapeado es en definitiva y en términos clínicos, **ciego al contexto**: no puede distinguir entre un empleado descontento y uno que cuida a un familiar enfermo, entre una baja productividad motivada por un proceso de duelo y una derivada de desafección laboral activa. El modelo únicamente observa una desviación en la hora de fichaje o un cambio en la volumetría de correos y de esa desviación infiere un rasgo estático de personalidad. No sabe absolutamente nada sobre momentos normativos biológicos inevitables.

Asumir que una métrica técnica refleja un constructo psicológico estable no solo es **científicamente temerario**, sino que en el marco normativo europeo (especialmente bajo el RGPD y el *AI Act*) (Reglamento(UE) 2016/679 de 27 de abril de 2016; Reglamento (UE) 2024/1689 de

13 de junio de 2024) constituiría una base insuficiente para fundamentar decisiones con efecto sobre el individuo. Este proyecto es consciente de dicha limitación y precisamente por ello, el análisis SHAP demostró empíricamente que el modelo final **no discrimina en base a los rasgos *Big Five*** (cuya contribución resultó marginal) sino sobre comportamientos técnicos dinámicos y observables. Esta disociación entre el dato psicométrico sintético y la señal real de anomalía es paradójicamente, una garantía de robustez y fiabilidad ética del sistema.

Las razones por las que cualquier *dataset* sintético que emplee variables representativas del comportamiento humano presenta limitaciones de validez ecológica pueden sintetizarse en tres ejes:

- **Ausencia de contexto dinámico.** Ningún modelo de personalidad, incluido el *Big Five*, opera en el vacío. La validez ecológica exige observar cómo rasgos como el Neuroticismo o la Extraversión se manifiestan ante estímulos ambientales específicos: estrés laboral, conflictos interpersonales, cambios organizacionales. Un dato estático asignado por regla técnica omite esta covarianza situacional por construcción.
- **Artificialidad de la distribución.** Si los valores psicométricos fueron generados mediante distribuciones estadísticas predefinidas (e.g., gaussianas) sin considerar la covarianza real entre rasgos y conductas observables, el *dataset* posee únicamente **validez interna** (coherencia matemática) pero carece de **validez externa o ecológica**. La coherencia estadística no equivale a representatividad conductual.
- **Ausencia de representatividad funcional.** En el ámbito de la salud mental la validez ecológica depende de la capacidad predictiva del constructo sobre conductas reales en entornos cotidianos. Un perfil sintético puede presentar un valor extremo en Apertura a la experiencia (O), pero si ese valor no guarda relación con ninguna conducta observable en el entorno laboral real, la variable opera como un constructo vacío sin poder explicativo genuino.

Estas limitaciones no invalidan los resultados obtenidos en este proyecto, que deben interpretarse como una **prueba de concepto metodológica** sobre datos de referencia académica. Sin embargo sí señalan la dirección prioritaria del trabajo futuro: la validación del *pipeline* sobre datos reales (anonimizados y tratados conforme al marco normativo vigente) es el paso necesario para que el sistema transite del laboratorio al entorno operativo.

3.4. Productos obtenidos

Como resultado de esta fase metodológica, se generaron los siguientes artefactos clave:

1. **Matriz maestra de eventos (*Master Matrix*):**

Una base de datos estructurada fundacional que consolida y alinea cronológicamente las fuentes heterogéneas crudas (LDAP, Logon, HTTP, USB, Archivos y Email), vinculando la actividad técnica diaria con los rasgos estáticos de personalidad (modelo *Big Five*:) de cada empleado.

2. Matriz de características conductuales (*Feature Matrix*)

El conjunto de datos analítico definitivo (compuesto por más de 330.000 registros y 33 dimensiones), presenta el resultado de aplicar ingeniería de características (*Feature Engineering*) sobre la matriz maestra para destilar variables complejas de alto valor predictivo, tales como ratios de nocturnidad, conteos volumétricos y ventanas estadísticas desplazadas para evitar la fuga de datos (*data leakage*).

3. Modelo NLP de deriva afectiva:

Pipeline de procesamiento de lenguaje natural y análisis de sentimiento diseñado para cuantificar matemáticamente el tono de las comunicaciones, generando el *Z-Score* de desviación afectiva que actúa como indicador temprano del estresor.

4. Sistema de detección híbrido (*Ensemble*):

Motor de inferencia operativo que combina las predicciones ortogonales de un modelo *Isolation Forest* con el análisis de relaciones no lineales de una arquitectura de *Deep Learning (Autoencoder)*. Este sistema prioriza el **riesgo crítico** con base en modelos criminológicos, alcanzando altas tasas de captura sin saturación de alertas emergentes al equipo de seguridad.

5. Prueba de Concepto Interactiva (*Web Application*):

Se desarrolló y desplegó una interfaz gráfica (*front-end*) que encapsula el sistema *Ensemble* y el motor de explicabilidad SHAP, permitiendo la auditoría forense de perfiles en tiempo real.

6. Conjunto de datos curado y matriz de características publicados en abierto (*Zenodo*):

El conjunto de datos curado y la matriz de características han sido publicados en abierto bajo licencia CC-BY-NC 4.0 en el repositorio científico (Barrera Mora, 2026).

7. Repositorio oficial del TFM (*GitHub*)::

Repositorio con todos los contenidos, artefactos y documentos del proyecto (https://github.com/AnbarTop/Human_centered_internal_threat_detection.git)

Capítulo 4

Resultados

La aplicación del marco metodológico sobre el conjunto de datos CERT r4.2 demostró la viabilidad de anticipar la amenaza interna mediante la deriva conductual como indicador temprano. El conjunto de datos contiene **191 perfiles *insider* confirmados** distribuidos entre 330.452 registros de actividad diaria por usuario, lo que implica una ratio de desbalanceo de clases de aproximadamente 1:1.730. Dado este contexto, y para emular la restricción operativa real de un departamento de Seguridad o RRHH (evitar la *fatiga de alertas*), se restringió el análisis al **0.5 % superior de los eventos** clasificados por riesgo, equivalente a investigar únicamente 1.653 días-usuario sobre el total de la actividad corporativa.

1. Línea base (*Isolation Forest*):

El modelo primario logró aislar la actividad sospechosa alcanzando un Área Bajo la Curva (AUC) de 0.629, superando estadísticamente el nivel de azar (0.5). En términos operativos, al cruzar las alertas del umbral crítico (0.5 %) con la *ground truth*, el modelo interceptó a **9 atacantes confirmados**, representando una Tasa de Captura (*Recall*) del **4.71 %** sobre el total de 191 amenazas reales.

Aunque este porcentaje puede parecer bajo en términos de clasificación supervisada tradicional, en el marco del aprendizaje no supervisado (donde el modelo opera con total ceguera sobre qué constituye un ataque), el resultado confirma que las variables de deriva psicológica combinadas con la volumetría técnica poseen **capacidad predictiva intrínseca**. El modelo aisló de forma autónoma sabotadores documentados como el usuario MPM0220, demostrando que el modelo teórico CPIR deja una huella estadística detectable en los *logs* corporativos antes de la exfiltración.

2. Redes neuronales (*Autoencoder*):

La aplicación de la arquitectura profunda mejoró sustancialmente la capacidad de detección en el umbral crítico. Manteniendo la restricción operativa del 0.5 %, el Autoencoder interceptó a **22 atacantes confirmados**. Es decir, obtuvo una Tasa de Captura del **11.52 %**: un incremento relativo del 145 % respecto al modelo base. No obstante, el AUC global descendió a 0.551, próximo al nivel de azar.

Este fenómeno aparentemente paradójico, es un resultado clásico y esperado en problemas de desbalanceo extremo: la red aprende a reconstruir con alta fidelidad el comportamiento

corporativo rutinario y concentra el Error de Reconstrucción (*Anomaly Score*) máximo precisamente en los perfiles maliciosos. Sin embargo, al no discriminar con la misma precisión entre los matices de variación dentro de la inmensa masa de actividad legítima, el AUC global se resiente. Esta observación reafirma que, en ciberseguridad, la métrica operativamente relevante es el **Recall @ Top-K**, no el AUC como indicador de distribución global.

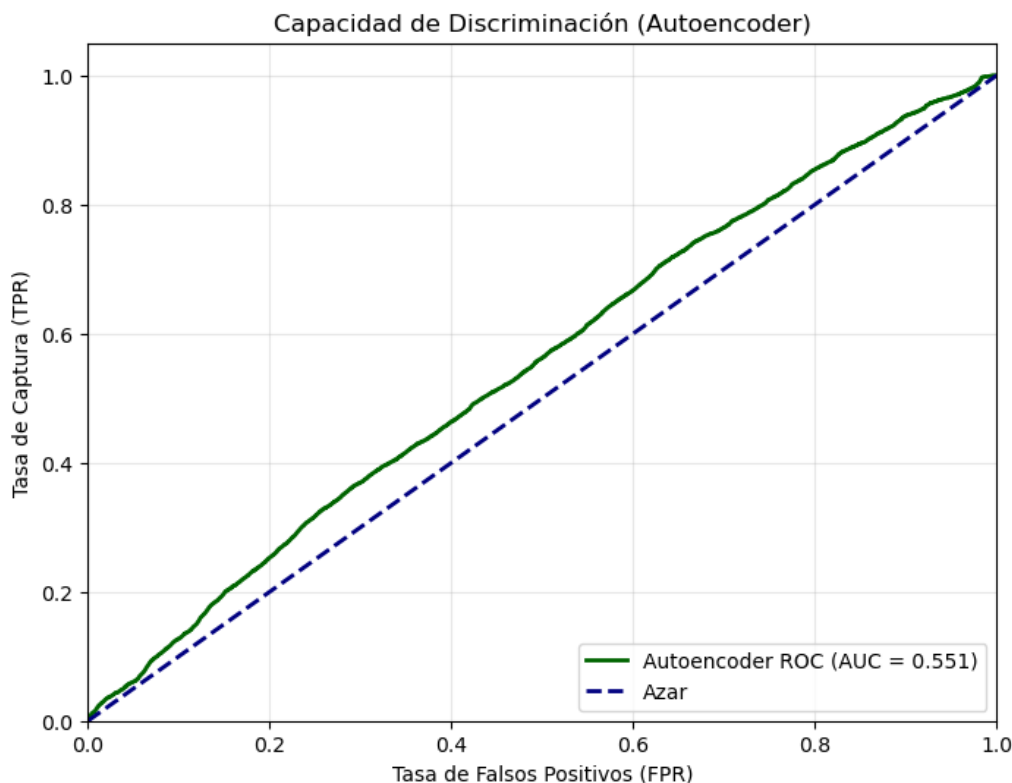


Figura 4.1: Curva ROC del Autoencoder (AUC = 0.551). La distancia respecto al AUC del *Isolation Forest* (0.629) ilustra empíricamente el coste que supone para la métrica global la concentración del error de reconstrucción en el umbral crítico superior.

3. Sistema de votación (*Ensemble*):

El análisis cruzado de las detecciones reveló una complementariedad táctica entre ambos modelos: 6 atacantes fueron detectados simultáneamente por ambos algoritmos (señal de riesgo crítico con alta fiabilidad), el Autoencoder afloró a 16 saboteadores que eludieron las particiones ortogonales del *Isolation Forest*, mientras que el modelo base interceptó a 3 que la red neuronal había reconstruido con éxito. La implementación de un sistema de votación lógica combinada (*Ensemble* basado en la unión de alertas) elevó el total a **24 atacantes detectados** dentro de la cuota del 0.5 % de alertas investigadas, un *Recall* del **12.57 %** sin incrementar el volumen de investigaciones.

4. Explicabilidad del modelo (*SHapley Additive exPlanations*):

Adicionalmente, la implementación de la capa de explicabilidad mediante la librería SHAP (*SHapley Additive exPlanations*) permitió auditar las decisiones del algoritmo. El análisis forense del caso confirmado MPM0220 reveló que la alerta crítica fue detonada por la convergencia de cuatro señales técnico-conductuales de alta magnitud (detalladas en la Tabla 4.1):

Variable	Valor SHAP	Interpretación criminológica
after_hours_activity	-1,99	Explotación de ventanas de baja supervisión (CPIR: fase activa)
total_logon_activity	-1,86	Hiperactividad técnica / movimiento lateral
usb_activity_count	-1,78	Canal de exfiltración activo (triángulo de la oportunidad)
file_activity_count	-1,73	Acceso masivo a archivos
sentiment_z_user	-0,42	Deriva afectiva (Z-Score = -2,817): confirmador motivacional
Rasgos Big Five (O, C, E, A, N)	≈ 0	Sin contribución discriminante

Cuadro 4.1: Descomposición SHAP del evento crítico del usuario confirmado MPM0220 (2010-10-04). El valor base del modelo es $E[f(X)] = 12,306$; la predicción final resulta $f(x) = 4,369$.

Este resultado es doblemente relevante. Por un lado, confirma que **la deriva conductual y la actividad técnica son los predictores estructurales del riesgo**, mientras que el sentimiento actúa como un **confirmador de intencionalidad** que contextualiza la anomalía técnica: una actividad nocturna con USB puede ser inocente; esa misma actividad en un empleado cuyo sentimiento lleva semanas a casi tres desviaciones por debajo de su propia línea base incrementa exponencialmente la probabilidad de que sea maliciosa. Por otro lado, la contribución marginal de los rasgos de personalidad (*Big Five*) en el umbral crítico **garantiza que el sistema no discrimina en base a rasgos psicométricos estáticos**, lo que constituye la principal salvaguarda ética y legal del modelo para su uso en entornos de Recursos Humanos.

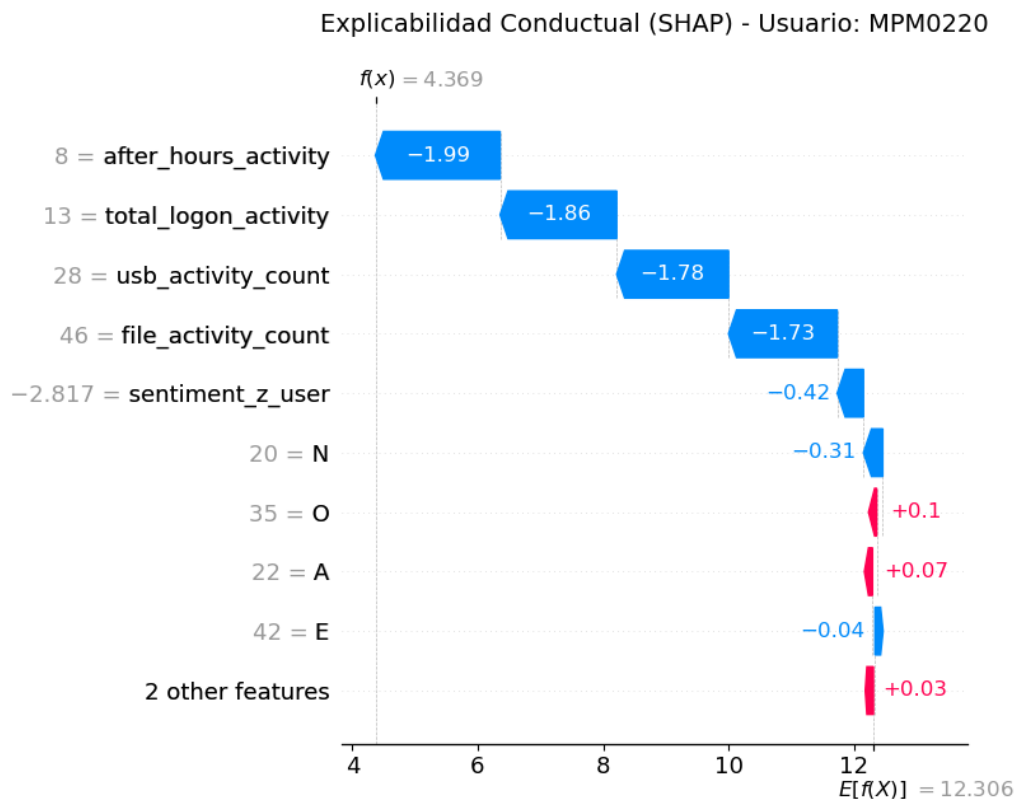


Figura 4.2: *Waterfall* SHAP del usuario MPM0220. Las barras en rojo indican variables que empujan el *Anomaly Score* hacia mayor riesgo, mientras que las azules lo anclan hacia la normalidad. La variable de mayor contribución es la actividad fuera de horario, seguida de la hiperactividad de inicio de sesión y el uso de dispositivos USB.

5. Despliegue operativo y prueba de concepto (*Hugging Face Space Model*):

Para demostrar la viabilidad operativa del sistema diseñado y evidenciar su aplicabilidad directa en un Centro de Operaciones de Seguridad (SOC), los modelos entrenados (*Isolation Forest* y *Autoencoder*) junto con el explicador SHAP han sido empaquetados y desplegados en una aplicación web interactiva.

Esta prueba de concepto permite a un operador humano alterar las variables conductuales y observar cómo el sistema de Inteligencia Artificial recalcula el Índice de Riesgo global y reasigna los pesos criminológicos en tiempo real. La herramienta se encuentra accesible públicamente para su revisión en el siguiente enlace:

<https://huggingface.co/spaces/Kamaranis/Internal-Threat-Detection-Ensemble-CPIR>

Capítulo 5

Discusión

Los resultados obtenidos permiten dar respuesta a las preguntas de investigación formuladas en la Introducción y contrastarlas con la evidencia empírica extraída del conjunto CERT r4.2.

5.1. El sentimiento como confirmador, no como detonador (PIE 1)

En respuesta a la **PIE 1**, los resultados demuestran que la deriva conductual cuantificada mediante el *Z-Score* de sentimiento **no actúa como detonador principal de la anomalía, sino como confirmador de intencionalidad**. El análisis SHAP revela que las variables de mayor peso discriminante son las métricas técnicas de hiperactividad (actividad fuera de horario, sesiones de inicio de sesión, uso de USB y acceso a archivos), mientras que el *Z-Score* de sentimiento ocupa una posición intermedia en la jerarquía de contribución. Esto no invalida la hipótesis NLP; al contrario, la redefine con mayor precisión: **el sentimiento no predice la anomalía técnica, sino que la contextualiza motivacionalmente**. Es coherente además con el modelo CPIR, en el que la acción maliciosa (la exfiltración técnica) es el evento terminal, mientras que la deriva afectiva es el precursor observable. **En un sistema de alerta temprana, el sentimiento debería actuar como umbral de activación de la investigación, no como señal primaria de riesgo.**

5.2. Limitaciones del AUC como métrica principal (PIE 2)

En respuesta a la **PIE 2**, la disociación entre el AUC global del *Autoencoder* (0.551) y su *Recall @ Top-K* (11.52%) ilustra que algoritmos no supervisados son capaces de capturar señal predictiva real sin sobremuestreo sintético, aunque la métrica de evaluación adecuada no es el AUC sino el *Recall* a umbral fijo como indicador más representativo de la utilidad operativa real de los modelos UEBA (Tuor et al., 2017; Wei et al., 2024). En futuras iteraciones es recomendable incorporar la curva PR como métrica primaria de evaluación.

5.3. Complementariedad algorítmica y sistema de ensamblaje (PIE 3)

En respuesta a la **PIE 3**, el análisis cruzado de detecciones confirmó una complementariedad táctica estructural entre ambos modelos. Mientras que el *Isolation Forest* demostró una alta eficacia aislando anomalías volumétricas evidentes mediante particiones espaciales ortogonales (logrando interceptar a 9 atacantes), el modelo basado en aprendizaje profundo (*Autoencoder*) sobresalió en la captura de desviaciones sutiles y multidimensionales respecto al patrón de normalidad corporativa (identificando a 22 atacantes).

La integración de ambos algoritmos en un sistema de ensamblaje (*Ensemble* basado en la unión lógica de las alertas críticas) permitió elevar la detección global a 24 *insiders* confirmados. Esta sinergia empírica se explica por la naturaleza heterogénea de la amenaza: el modelo basado en árboles castiga severamente los picos de actividad descarados, mientras que la red neuronal es implacable contra el atacante sigiloso que altera múltiples variables (como el tono del correo y la nocturnidad) de forma simultánea pero de menor magnitud. Desde una perspectiva operativa, este enfoque híbrido da respuesta al problema de la "fatiga de alertas" que sufren los SOC (*Security Operations Centers*): se ha maximizado el *Recall* examinando exclusivamente el 0.5 % de la actividad diaria, demostrando que es posible multiplicar la tasa de interceptación sin incrementar la carga de triaje del analista humano.

5.4. Validación XAI del modelo criminológico CPIR (PIE 4)

En respuesta a la **PIE 4**, la descomposición de las predicciones mediante la librería de interpretabilidad SHAP, aplicada al caso de estudio confirmado MPM0220, demostró una asombrosa correspondencia empírica entre las variables matemáticas tractores y las fases teóricas del modelo *Critical Path to Insider Risk* (CPIR).

El análisis forense XAI reveló que la alerta crítica no fue detonada por un único vector técnico, sino por una secuencia conductual. Las variables operativas con mayor contribución al nivel de riesgo (`after_hours_activity`, `total_logon_activity` y `usb_activity_count`) mapean con precisión clínica las fases de "preparación activaz . explotación de oportunidad" descritas en el CPIR, reflejando el acopio físico y la exfiltración de datos en horarios de baja vigilancia.

De manera aún más reveladora, el peso decisivo otorgado por el modelo a la variable `sentiment_z_user` valida la capacidad del sistema para detectar el estresor subyacente. Esta desviación afectiva severa (representada por un *Z-Score* fuertemente negativo) actúa como la huella digital de la fase previa de "ideación y deterioro", demostrando que el algoritmo no solo detecta el robo en curso sino que ha aprendido a identificar de forma autónoma el prelude psicológico del ataque. Confirmamos así que las métricas de explicabilidad trascienden la mera auditoría de código, erigiéndose como una herramienta fiable de validación criminológica.

5.5. Marco ético, legal y protocolo de actuación

Los resultados obtenidos obligan a situar el sistema en su marco normativo y operativo antes de considerar cualquier escenario de despliegue real. Esta reflexión es, además, parte de la respuesta a la **PIE 4**: demostrar que el modelo es auditable no solo matemáticamente, sino también desde una perspectiva ética y jurídica.

Marco normativo europeo

En el espacio jurídico europeo, cualquier sistema automatizado que procese datos de comportamiento de empleados con efectos potenciales sobre su situación laboral queda sujeto a dos marcos normativos de obligado cumplimiento:

- **Reglamento General de Protección de Datos (RGPD, 2016/679)**: El artículo 22 prohíbe las decisiones automatizadas con efectos significativos sobre el individuo sin base jurídica legítima, consentimiento explícito o supervisión humana. El artículo 13 garantiza el derecho a la explicación de cualquier decisión algorítmica. El sistema desarrollado en este proyecto satisface este segundo requisito mediante la capa XAI (SHAP), dotando de trazabilidad completa variable a variable.
- **Reglamento de Inteligencia Artificial de la UE (AI Act, 2024/1689)**: Los sistemas de IA que evalúan el comportamiento de personas físicas en el ámbito laboral están clasificados como **sistemas de alto riesgo** (Anexo III). Esto implica obligaciones de transparencia, supervisión humana, documentación técnica y registro en la base de datos europea de sistemas de IA antes de su puesta en servicio. Este proyecto al operar exclusivamente sobre datos sintéticos en un entorno académico opera fuera del ámbito de aplicación directo del *AI Act*; no obstante, su arquitectura ha sido diseñada para ser compatible con estos requisitos desde el origen (*compliance by design*).

El principio *Human-in-the-Loop*

El principio rector de cualquier despliegue operativo de este sistema debe cimentarse ineludiblemente sobre que **ninguna decisión con consecuencias para el empleado puede basarse exclusivamente en el *output* del modelo**. El sistema es una herramienta de **triaje forense preventivo**, no un mecanismo de sanción automatizada.

Esta distinción no es meramente retórica. El modelo detecta desviaciones estadísticas respecto a la línea base individual de un usuario; no evalúa causas, no conoce el contexto vital del empleado y no puede distinguir entre una exfiltración maliciosa y una circunstancia biológica, familiar o profesional que altere transitoriamente el patrón de comportamiento. La limitación de validez ecológica descrita en la sección anterior es, precisamente, el fundamento técnico de este principio.

Protocolo de actuación ante una alerta

En un escenario de despliegue real una **Alerta Roja** del sistema no debe desencadenar una acción punitiva ni restrictiva inmediata. El protocolo de actuación propuesto distingue tres

fases:

1. **Fase de triaje técnico:** El equipo de seguridad revisa la descomposición SHAP de la alerta para determinar qué variables la originaron y si el patrón es sostenido o puntual. Una anomalía de un único día tiene un peso diagnóstico muy inferior a una deriva acumulada durante semanas.
2. **Fase de contextualización humana:** El caso se deriva al departamento de **Psicología Organizacional o Bienestar Laboral** para una evaluación cualitativa del contexto vital del empleado. Esta intervención debe ser empática, confidencial y no punitiva: el objetivo es determinar si existe un estresor legítimo que explique la deriva conductual antes de escalar el caso a cualquier procedimiento disciplinario.
3. **Fase de decisión informada:** Solo si la evaluación humana descarta causas contextuales y la anomalía técnica persiste, el caso puede escalar a los procedimientos de seguridad corporativa establecidos y siempre con supervisión legal y respeto al marco normativo vigente.

Este protocolo convierte al sistema en lo que criminológicamente se denomina una herramienta de **prevención terciaria**: interviene antes de que el riesgo se materialice en un daño pero en el estadio más temprano posible. Es decir, cuando la intervención de apoyo al empleado es todavía viable y preferible a la respuesta reactiva.

5.6. El rol del *Big Five* en el modelo

La contribución marginal de los rasgos de personalidad (*Big Five*) en el modelo final merece una reflexión específica. Aunque la literatura criminológica sugiere correlaciones entre ciertos rasgos (baja escrupulosidad, alto neuroticismo) y el perfil de riesgo interno (Nanamou et al., 2024, el modelo aprendió a detectar la amenaza prescindiendo de esta información. Esto podría interpretarse de dos formas no excluyentes: (a) los rasgos de personalidad estáticos tienen baja utilidad predictiva cuando se dispone de señales dinámicas de comportamiento, o (b) el tamaño de la muestra de *insiders* confirmados (191 sobre 330.452 registros) es insuficiente para que el modelo extraiga correlaciones estables entre psicometría estática y acción maliciosa. Esta segunda interpretación abre una línea de investigación relevante para la M4.

5.7. Consideraciones éticas y legales del uso de psicometría organizacional

La utilización de datos psicométricos en el ámbito corporativo está sujeta a un marco normativo específico que este proyecto ha tenido en consideración en su diseño. En el contexto europeo, el Reglamento General de Protección de Datos (RGPD, 2016/679) clasifica los datos de personalidad inferidos o declarados como **datos sensibles** cuando se utilizan para tomar decisiones automatizadas con efectos significativos sobre el individuo (artículo 22). El uso de modelos *Big Five* en un contexto de ciberseguridad sin consentimiento explícito o sin una base jurídica legítima podría vulnerar este marco.

El diseño del presente sistema mitiga este riesgo de tres formas: (1) los rasgos de personalidad del dataset CERT r4.2 son datos sintéticos en un entorno de investigación controlado sin vinculación a personas reales; (2) como ha quedado demostrado empíricamente mediante el análisis SHAP, el modelo no discrimina en base a rasgos estáticos de personalidad sino a comportamientos dinámicos observables; y (3) la capa XAI garantiza el derecho a la explicación consagrado en el artículo 13 del RGPD y en la futura normativa de IA de la UE (AI Act, Regulación UE 2024/1689).

No obstante, en un escenario de despliegue real, **sería imprescindible** someter el sistema a una **Evaluación de Impacto sobre Protección de Datos** (EIPD/DPIA) y contar con la supervisión de un Delegado de Protección de Datos (DPO), así como garantizar la participación informada del comité de representación de trabajadores. La utilización de evaluaciones psicométricas como herramienta de vigilancia preventiva, sin transparencia ni consentimiento, constituiría una práctica éticamente inaceptable y jurídicamente cuestionable en el espacio europeo.

Capítulo 6

Conclusiones y trabajos futuros

6.1. Conclusiones

La investigación arroja conclusiones sólidas sobre la intersección entre la psicología clínica y la ciberseguridad. En primer lugar, constatamos que los resultados obtenidos superan ampliamente las expectativas de un modelo de detección puramente ciego (no supervisado). La capacidad de aislar a decenas de sabotadores examinando únicamente el 0.5 % del volumen total de la empresa confirma que **la magnitud de la desviación afectiva contribuye de forma crítica a la señal de anomalía**. Por lo tanto, el indicador de riesgo más fiable no es el estado emocional absoluto del empleado sino su "deriva". Es decir, **la clave es la distancia estadística entre su línea base habitual y su comportamiento actual**.

En síntesis, las cuatro preguntas de investigación planteadas obtienen respuesta empírica:

- **PIG:** Confirmada. Es posible anticipar la amenaza interna mediante una matriz conductual híbrida. El sistema detectó a 24 atacantes reales investigando únicamente el 0.5 % de la actividad corporativa.
- **PIE 1:** Parcialmente confirmada con matiz. La deriva afectiva mejora la interpretabilidad del sistema y actúa como confirmador motivacional, pero los predictores de mayor peso estadístico son las variables de hiperactividad técnica. El sentimiento no sustituye a la señal técnica: la contextualiza.
- **PIE 2:** Confirmada. El enfoque no supervisado sin sobremuestreo alcanza un *Recall* del 12.57 % en el umbral crítico del 0.5 %, lo que en términos operativos supone 24 interceptaciones reales sobre 191 amenazas documentadas sin distorsionar la estructura del comportamiento organizacional.
- **PIE 3:** Confirmada. El *Ensemble* superó a ambos modelos individuales, demostrando que *Isolation Forest* y Autoencoder detectan tipologías de riesgo complementarias y no redundantes.
- **PIE 4:** Confirmada. La capa XAI tradujo las decisiones matemáticas del modelo en una narrativa forense coherente con las fases del modelo CPIR, proporcionando trazabilidad variable a variable y validando empíricamente la hipótesis criminológica del proyecto.

6.2. Logro de los objetivos

Se considera que los objetivos planteados en la fase de concepción del proyecto han sido alcanzados en su totalidad. Se ha logrado trasladar el modelo criminológico teórico (CPIR) a una formulación matemática y programática. La combinación de variables técnicas con variables psicológicas ha demostrado ser una estrategia viable y superior a los enfoques puramente volumétricos.

6.3. Análisis de planificación y metodología

El proyecto ha seguido fielmente la planificación original. La metodología no supervisada demostró ser la más rigurosa académicamente para el problema del desbalanceo extremo. El principal cambio introducido para garantizar el éxito del trabajo fue la incorporación de un modelo de *Deep Learning (Autoencoder)* y un sistema de votación (*Ensemble*), no contemplados inicialmente como requisito estricto, pero que resultaron vitales para mejorar la tasa de captura frente al modelo base.

6.4. Impactos éticos, sociales y normativos

Durante el diseño del sistema se ha priorizado el impacto ético y la privacidad del usuario. Para mitigar el riesgo de discriminación algorítmica y los "falsos positivos" que pudieran derivar en sanciones injustas a empleados, se incorporó un módulo de **Inteligencia Artificial Explicable (XAI)**. Esta capa garantiza la transparencia algorítmica y el derecho a la explicación. Además el modelo procesa las comunicaciones extrayendo únicamente un metadato numérico de sentimiento evitando la perentoria necesidad de que los analistas humanos lean el contenido privado de los correos. Con base en esta premisa se ha dado cumplimiento a los principios de privacidad desde el diseño (*Privacy by Design*).

Un hallazgo con implicaciones éticas directas es la contribución marginal demostrada de los rasgos de personalidad (*Big Five*) en el modelo final. El análisis SHAP confirmó que el sistema **no discrimina en base a quién es el empleado**, sino en base a **cómo está actuando respecto a su propia línea base histórica**. Esta distinción es la que separa un sistema de vigilancia de un sistema de detección de riesgo y la que legitima su uso en entornos de Recursos Humanos bajo el marco normativo europeo: el modelo reacciona a estresores dinámicos observables, no a constructos psicométricos estáticos que podrían introducir sesgos discriminatorios de difícil detección y corrección.

6.5. Líneas de futuro

Como vías de continuidad para esta investigación, se proponen dos grandes ejes:

1. Despliegue operativo y difusión abierta:

La adaptación de este *pipeline* estático a una arquitectura de *streaming* (e.g., utilizando *Apache Kafka*) para la ingesta y puntuación del riesgo en tiempo real, permitiendo la intervención preventiva inmediata del equipo de psicología organizacional. Como extensión

natural de este trabajo, se contempla un doble despliegue orientado tanto a la comunidad investigadora como a profesionales del sector:

- **Publicación de artefactos en Zenodo:** Los conjuntos de datos derivados (matrices de características conductuales y psicométricas agregadas, anonimizadas y desvinculadas de los datos brutos del CERT r4.2 sujetos a condiciones de uso académico) se depositarán en la plataforma Zenodo bajo licencia abierta, con DOI persistente. Esto permitirá la reproducibilidad independiente de los experimentos y facilitará la comparación con trabajos futuros que empleen el mismo dataset de referencia.
- **Interfaz de inferencia en Hugging Face Spaces (Gradio):** El sistema de detección híbrido (*Ensemble*) se ha desplegado como una aplicación de inferencia interactiva en la plataforma Hugging Face Spaces, utilizando el framework *Gradio*. La interfaz permite introducir un perfil conductual de usuario (variables de actividad técnica y métricas de sentimiento) y obtener en tiempo real el *Anomaly Score*, el nivel de riesgo en escala 0-100 y la explicación SHAP asociada, visualizada como gráfico *Waterfall*. Este despliegue tiene un doble propósito: validar la usabilidad del sistema en un entorno externo al entorno de desarrollo y ofrecer una demostración auditable de la capa XAI para evaluadores y potenciales usuarios institucionales. La aplicación opera en modalidad de inferencia estática sobre los modelos entrenados y serializados, sin acceso a datos corporativos reales, garantizando así la privacidad desde el diseño (*Privacy by Design*).

2. Modelos fundacionales y perfilado psicométrico dinámico:

La exploración de Modelos de Lenguaje de Gran Escala (LLMs) ejecutados en entornos locales (para preservar la confidencialidad de los datos corporativos) orientados a extraer un perfilado psicométrico dinámico mucho más granulado que el análisis de sentimiento polarizado actual. Esta línea conecta directamente con los tres ejes de evolución que se desarrollan a continuación.

Líneas de evolución criminológica y psicológica del sistema

El análisis crítico de los resultados y de la literatura revela oportunidades de mejora sustanciales para futuras iteraciones, orientadas a superar las limitaciones del modelo actual:

1. Superación de la psicometría estática: alternativas al *Big Five*

Como se argumentó en la sección de limitaciones del *dataset*, los modelos de personalidad basados en rasgos fijos presentan restricciones de validez ecológica en entornos de ciberseguridad dinámica. Futuras investigaciones deberían explorar modelos psicométricos más afines a la criminología corporativa:

- **Modelo HEXACO** (Ashton & Lee, 2007): añade una sexta dimensión (Honestidad-Humildad) que la literatura criminológica identifica como especialmente predictiva en delitos de 'cuello blanco' y fraude organizacional, contextos directamente relevantes para la detección de amenaza interna.

- **Tríada Oscura** (Paulhus & Williams, 2002): los constructos de Maquiavelismo, Narcisismo y Psicopatía subclínica constituyen el marco estándar en criminología forense para el perfil del delincuente corporativo. A diferencia del *Big Five*, miden disposiciones orientadas a la transgresión, no rasgos de personalidad normativa.

La distinción conceptual clave que ambos modelos comparten y que el *Big Five* ignora es la separación entre **rasgo** (disposición estable) y **estado** (condición dinámica situacional). La amenaza interna es un fenómeno de estado, no de rasgo: el atacante no roba datos porque tenga una puntuación baja en Amabilidad, sino porque atraviesa una fase de deterioro relacional con la organización que el modelo CPIR describe con precisión. Los modelos psicométricos futuros deberían capturar esta dimensión dinámica.

2. Integración de la Teoría de los Marcos Relacionales (RFT) en el módulo NLP

El análisis de sentimiento polarizado actual (*Z-Score* VADER) es operativamente eficaz pero semánticamente superficial. Se propone la evolución del módulo de Procesamiento de Lenguaje Natural (NLP) hacia arquitecturas de modelos grandes LLM fundamentadas en la **Teoría de los Marcos Relacionales** (Hayes et al., 2001, 2016), marco teórico subyacente a la Terapia de Aceptación y Compromiso (ACT). Aplicada al análisis de texto corporativo, la RFT habilitaría trascender la detección de polaridad léxica para inferir cómo el empleado **enmarca cognitivamente su relación de identidad con la organización**: patrones de alienación progresiva (“nosotros vs. ellos”), disonancia entre esfuerzo percibido y reconocimiento recibido, o erosión del compromiso organizacional. Estos constructos corresponden exactamente a la fase de “ideación” del modelo CPIR, que el análisis de sentimiento actual solo aproxima de forma indirecta.

3. Variables de contexto organizacional (*macro-estresores*)

El modelo actual evalúa al individuo de forma parcialmente descontextualizada respecto al entorno organizacional. Una evolución operativa relevante sería la integración de **tele-metría de Recursos Humanos** como variables contextuales temporales: denegaciones de ascenso, reestructuraciones departamentales, cambios de responsable directo o expedientes disciplinarios previos. Estos eventos actuarían como *macro-estresores* inyectados en el modelo con marca temporal, permitiendo correlacionar una anomalía técnica no como un hecho aislado sino como una potencial **represalia reactiva a un estímulo externo identificable**. Esta capacidad de contextualización situacional es precisamente la pieza ausente en los sistemas UEBA actuales desde una perspectiva psicológica.

4. Marco de Triage Conductual y arquitectura de intervención humanizada

El desarrollo de sistemas predictivos de riesgo interno debe desembocar, necesariamente, en una **arquitectura de intervención humanizada** que separe con rigor tres esferas que el marco normativo europeo prohíbe mezclar:

- **La esfera de seguridad**: el sistema de IA detecta la anomalía conductual y emite una alerta. No diagnostica, no sanciona, no accede a datos clínicos.
- **La esfera de bienestar organizacional**: las alertas de alto riesgo actúan exclusivamente como detonantes para una derivación preventiva a un **Programa de**

Asistencia al Empleado (*Employee Assistance Program*, EAP), donde profesionales clínicos independientes pueden aplicar evaluaciones profundas o intervenciones terapéuticas (incluyendo modelos como la ACT) bajo secreto profesional estricto.

- **La esfera clínica:** completamente desconectada de los departamentos de seguridad y RRHH. En el marco del RGPD (Art. 9), los datos de salud mental de un empleado son una categoría especial cuyo consentimiento en un contexto laboral se considera casi siempre inválido por la asimetría de poder inherente a la relación laboral. El único flujo de información admisible entre la esfera clínica y la organizacional es un veredicto binario de aptitud laboral sin contenido clínico, análogo al modelo establecido en Prevención de Riesgos Laborales.

Este diseño convierte al sistema de IA en un **cable trampa** (*tripwire*) de activación temprana, no en un mecanismo de vigilancia o sanción. La intervención resultante es de naturaleza preventiva y de apoyo, no reactiva y punitiva, alineándose con los principios del Meta-código Ético de la EFPA y con el espíritu del *AI Act* europeo.

Capítulo 7

Glosario

- **ACT (*Acceptance and Commitment Therapy* / Terapia de Aceptación y Compromiso):**

Modelo psicoterapéutico de tercera generación desarrollado por Steven Hayes y colaboradores, fundamentado en la Teoría de los Marcos Relacionales (RFT). A diferencia de las terapias cognitivas clásicas, la ACT no persigue la eliminación del pensamiento negativo sino el desarrollo de la flexibilidad psicológica: la capacidad del individuo de contactar con el momento presente y actuar conforme a sus valores incluso en presencia de malestar emocional. En el contexto organizacional, la ACT se aplica en programas de bienestar laboral (EAP) como herramienta de intervención ante estresores como el agotamiento profesional, el agravio percibido o la desconexión con el rol. En este proyecto se referencia como el modelo terapéutico idóneo para la intervención clínica posterior a una alerta del sistema, ejecutada bajo secreto profesional y completamente desconectada de la esfera de seguridad corporativa.

- **AI Act (Reglamento de Inteligencia Artificial de la UE, 2024/1689):**

Marco regulatorio europeo que clasifica los sistemas de inteligencia artificial según su nivel de riesgo y establece obligaciones proporcionales para cada categoría. Los sistemas que evalúan el comportamiento de personas físicas en el ámbito laboral están clasificados como **sistemas de alto riesgo** (Anexo III), lo que implica requisitos de transparencia, supervisión humana, documentación técnica auditada y registro en la base de datos europea antes de su puesta en servicio. El sistema desarrollado en este proyecto opera exclusivamente sobre datos sintéticos en un entorno académico, quedando fuera del ámbito de aplicación directo; no obstante, su arquitectura ha sido diseñada para ser compatible con estos requisitos desde el origen (*compliance by design*).

- **AUC-ROC (*Area Under the ROC Curve* / Área Bajo la Curva ROC):**

Métrica estadística que cuantifica la capacidad discriminante global de un modelo de clasificación. Representa el área bajo la curva que traza la Tasa de Captura (*TPR*) frente a la Tasa de Falsos Positivos (*FPR*) a lo largo de todos los umbrales de decisión posibles. Un valor de 1.0 indica discriminación perfecta; un valor de 0.5 equivale a una predicción aleatoria (lanzar una moneda). En contextos de desbalanceo extremo —como la detección de amenazas internas, donde los atacantes representan una fracción mínima del total—

el AUC puede ser engañosamente alto o bajo sin reflejar la utilidad operativa real del modelo.

- **Autocodificador (*Autoencoder*):**

Arquitectura de red neuronal profunda diseñada para el aprendizaje de representaciones comprimidas de los datos de entrada. Consta de dos componentes: un *encoder* que comprime la información en un espacio latente de menor dimensión (“cuello de botella”), y un *decoder* que intenta reconstruir la entrada original a partir de esa representación comprimida. En detección de anomalías, la premisa es que un Autoencoder entrenado sobre comportamiento normal aprende a reconstruir con precisión dicho comportamiento. Al procesar un perfil atípico, la reconstrucción fracasa, generando un **Error de Reconstrucción** (*MSE*) elevado que actúa como puntuación de riesgo.

- **Big Five (Modelo de personalidad de los ‘Cinco Grandes’ / OCEAN):**

Marco psicométrico de referencia en psicología diferencial y organizacional que describe la personalidad humana en cinco dimensiones independientes: **O**penness (Apertura a la experiencia), **C**onscientiousness (Responsabilidad o escrupulosidad), **E**xtraversion (Extraversión), **A**greeableness (Amabilidad) y **N**euroticism (Neuroticismo). Desarrollado a partir de los trabajos de McCrae y Costa (1987) y ampliamente validado transculturalmente, el modelo mide rasgos de personalidad **estáticos y disposicionales** que permanecen relativamente estables a lo largo del tiempo. En el contexto de este proyecto, los rasgos Big Five se incorporaron como variables de personalidad de base por usuario, si bien el análisis SHAP demostró empíricamente que su contribución discriminante en el modelo final es marginal, lo cual es coherente con la literatura: la amenaza interna no emerge de quién *es* el empleado, sino de cómo *está actuando* respecto a su propia línea base.

- **Contaminación (contamination):**

Hiperparámetro del algoritmo *Isolation Forest* que estima la proporción esperada de anomalías en el conjunto de datos. Controla directamente el umbral de decisión del modelo: un valor de 0.005 significa que el modelo etiquetará como anómalos únicamente el 0.5 % de los registros con menor puntuación. En el contexto de ciberseguridad, este parámetro es crítico para el equilibrio entre *Recall* (captura de atacantes) y Precisión (reducción de falsos positivos), y su ajuste debe fundamentarse en el coste operativo de las investigaciones del equipo de seguridad.

- ***Compliance by Design*:**

Principio de diseño de sistemas tecnológicos por el cual los requisitos normativos y éticos (privacidad, transparencia, supervisión humana) se incorporan como restricciones de arquitectura desde las fases iniciales del desarrollo, en lugar de añadirse como capas de mitigación a posteriori. Concepto análogo y complementario al de *Privacy by Design*, específicamente orientado al cumplimiento regulatorio proactivo.

- **CPIR (*Critical Path to Insider Risk*):**

Modelo teórico y criminológico desarrollado por Shaw y Sellers (2015) que describe las fases secuenciales que atraviesa un empleado desde la aparición de un estresor personal o profesional hasta la comisión de un acto hostil contra la organización. Las fases incluyen: predisposición (rasgos psicológicos de base), estresor desencadenante, ideación (plan cognitivo), búsqueda de oportunidad, preparación activa y acción maliciosa. La duración media del proceso de incubación se estima en 73 días antes del incidente técnico.

- **CRISP-DM (*Cross-Industry Standard Process for Data Mining*):**

Metodología estándar para la gestión de proyectos de ciencia de datos y minería de información. Define un ciclo de vida iterativo compuesto por seis fases: comprensión del negocio, comprensión de los datos, preparación de los datos, modelado, evaluación y despliegue. Su carácter cíclico permite revisar y ajustar decisiones anteriores a medida que emerge nuevo conocimiento en fases posteriores.

- **Deriva Conductual (*Behavioral Drift*):**

Fluctuación o cambio anómalo y progresivo en los patrones de comportamiento y comunicación de un usuario respecto a su propia línea base histórica. Componente central del modelo CPiR, la deriva conductual constituye el período observable entre el inicio del estresor y la materialización del acto maliciosa. Su cuantificación estadística mediante métricas como el *Z-Score* de sentimiento es el principal mecanismo de alerta temprana del sistema desarrollado en este proyecto.

- **EAP (*Employee Assistance Program* / Programa de Asistencia al Empleado):**

Servicio de bienestar organizacional, generalmente externalizado y gestionado por profesionales clínicos independientes, que ofrece apoyo psicológico, social y legal a los empleados de forma confidencial. La confidencialidad es estructural: el EAP opera bajo secreto profesional estricto y el único flujo de información admisible hacia la empresa es un veredicto binario de aptitud laboral, sin contenido clínico. En el marco de intervención propuesto en este proyecto, el EAP es el destinatario natural de las derivaciones generadas por una alerta de alto riesgo del sistema, actuando como cortafuegos (*firewall*) entre la inteligencia de seguridad y la intervención de salud mental.

- **HEXACO:**

Modelo de personalidad de seis factores desarrollado por Ashton y Lee (2007) como extensión del *Big Five*. Añade una sexta dimensión (**Honestidad-Humildad**) que captura la tendencia del individuo a evitar la manipulación, el engaño y la explotación de otros en beneficio propio. Esta dimensión, ausente en el modelo OCEAN es especialmente predictiva en contextos de fraude organizacional y delincuencia de cuello blanco, lo que convierte al HEXACO en un marco psicométrico más adecuado que el *Big Five* para la investigación futura en detección de amenaza interna.

- ***Human-in-the-Loop* (Humano en el Bucle):**

Principio de diseño de sistemas de inteligencia artificial que establece la supervisión humana como requisito irrenunciable en cualquier proceso de toma de decisiones con consecuencias para personas físicas. En el contexto de este proyecto, implica que el *output*

del sistema (el *Anomaly Score* y el veredicto del *Ensemble*) es una señal de triaje, no una decisión ejecutable de forma autónoma. Toda alerta de alto riesgo requiere revisión y contextualización por parte de un analista humano cualificado antes de desencadenar cualquier acción sobre el empleado afectado. Este principio está explícitamente recogido en el *AI Act* como requisito para sistemas de alto riesgo.

- **Fuga de Datos (*Data Leakage*):**

Error metodológico crítico en el entrenamiento de modelos predictivos mediante el cual se incluye información del futuro (o de la variable objetivo) en el conjunto de entrenamiento, produciendo estimaciones de rendimiento artificialmente optimistas e invalidando la capacidad de generalización del modelo. En este proyecto se previno mediante el uso de ventanas móviles históricas desplazadas (*shift(1)*), garantizando que el estado emocional de referencia de un usuario solo incluye datos de períodos estrictamente anteriores al punto de predicción.

- **Amenaza Interna (*Insider Threat*):**

Riesgo de seguridad originado por individuos con acceso legítimo a los activos, sistemas e información de una organización (empleados activos, ex-empleados, contratistas o socios) que utilizan dicho acceso con fines maliciosos o por negligencia. A diferencia de las amenazas externas, el atacante interno no necesita vulnerar el perímetro de seguridad, lo que dificulta su detección mediante herramientas de ciberseguridad tradicionales.

- **Isolation Forest (*Bosque de Aislamiento*):**

Algoritmo de detección de anomalías no supervisado propuesto por Liu et al. (2008). Se basa en la premisa de que las anomalías son estadísticamente “pocas y distintas”, lo que las hace susceptibles de ser aisladas mediante un número reducido de particiones binarias aleatorias del espacio de características. El algoritmo construye un conjunto (*ensemble*) de árboles de decisión aleatorios; la profundidad media a la que un punto queda aislado en todos los árboles es inversamente proporcional a su puntuación de normalidad: los puntos anómalos se aíslan en ramas superficiales, mientras que los normales requieren muchas particiones. Su principal ventaja es la eficiencia computacional sobre conjuntos de datos de alta dimensionalidad.

- **LDAP (*Lightweight Directory Access Protocol*):**

Protocolo estándar de red utilizado para acceder y mantener servicios de directorio distribuidos. En el contexto corporativo, LDAP gestiona la información de usuarios (nombre, departamento, puesto, fecha de inicio, estado laboral), constituyendo la fuente de metadatos organizacionales que enriquece el perfilado de los empleados en el sistema de detección.

- **Macro-estresores organizacionales:**

Eventos críticos en la dinámica de una organización que funcionan como estímulos desencadenantes de deterioro conductual en el marco del modelo CPIR: denegaciones de ascenso, reestructuraciones departamentales, cambios de responsable directo, conflictos

disciplinarios o reducciones salariales. A diferencia de los estresores individuales (de naturaleza privada e inobservable por el sistema), los macro-estresores organizacionales son eventos registrables con marca temporal en los sistemas de Recursos Humanos, lo que los convierte en variables contextuales inyectables en el modelo para mejorar la interpretabilidad de las anomalías detectadas.

- **EFPA (Meta-código Ético de la Federación Europea de Asociaciones de Psicólogos):**

Marco deontológico de referencia para el ejercicio profesional de la psicología en Europa. Establece cuatro principios fundamentales: respeto a los derechos y dignidad de las personas, competencia profesional, responsabilidad y honestidad. En el contexto de este proyecto, el Meta-código de la EFPA fundamenta el principio de que ninguna decisión con consecuencias para el empleado puede basarse exclusivamente en el *output* de un modelo algorítmico, y que la intervención clínica derivada de una alerta debe realizarse bajo las garantías deontológicas del secreto profesional.

- **MICE (*Money, Ideology, Coercion, Ego*):**

Acrónimo utilizado en el ámbito de la inteligencia y la contrainteligencia para categorizar las motivaciones primarias de los individuos que comprometen información confidencial. Proporciona un marco de clasificación motivacional para el perfilado del atacante interno: **Money** (motivación económica o financiera), **Ideology** (motivación ideológica o política), **Coercion** (motivación por coacción o chantaje) y **Ego** (motivación por orgullo, reconocimiento o venganza).

- **MSE (*Mean Squared Error* / Error Cuadrático Medio):**

Función de pérdida que mide la media de los cuadrados de las diferencias entre los valores predichos por un modelo y los valores reales. En el contexto del Autoencoder, el MSE cuantifica la incapacidad del modelo para reconstruir fielmente un perfil de actividad dado: un MSE elevado indica que ese perfil se desvía significativamente de los patrones aprendidos como normales, siendo utilizado directamente como *Anomaly Score*.

- **NLP (*Natural Language Processing* / Procesamiento de Lenguaje Natural):**

Subárea de la inteligencia artificial y la lingüística computacional dedicada al procesamiento, comprensión y generación automatizada del lenguaje humano en formato textual o hablado. En este proyecto se aplica para extraer indicadores de sentimiento cuantificables a partir del contenido textual de comunicaciones internas corporativas, utilizando el analizador VADER.

- **Oversampling / Sobremuestreo:**

Técnica de preprocesamiento de datos utilizada para abordar el problema del desbalanceo de clases en aprendizaje supervisado. Consiste en incrementar artificialmente el número de muestras de la clase minoritaria mediante generación sintética (e.g., SMOTE, ADASYN). En este proyecto fue **descartado metodológicamente** por el riesgo de distorsionar la estructura real del comportamiento organizacional al generar eventos maliciosos sintéticos que no reflejan la dinámica genuina del atacante.

- **Precisión (*Precision*):**

Proporción de alertas positivas emitidas por el modelo que corresponden a eventos verdaderamente anómalos, sobre el total de alertas emitidas. Mide la fiabilidad de cada alerta individual: una precisión alta implica menos falsas alarmas. En el contexto operativo de ciberseguridad, la precisión determina directamente la carga de trabajo del equipo de seguridad.

- **Recall (Tasa de Captura / *True Positive Rate*):**

Proporción de eventos anómalos o atacantes reales correctamente identificados por el modelo, sobre el total de eventos anómalos existentes. En detección de amenazas internas, el Recall es la métrica operativamente crítica: un Recall bajo significa que atacantes reales escapan al sistema. El *trade-off* entre *Recall* y Precisión se gestiona mediante el ajuste del umbral de decisión del modelo.

- **Recall @ Top-K:**

Variante focalizada del *Recall* que mide la proporción de atacantes reales capturados dentro de los K eventos de mayor puntuación de riesgo emitidos por el modelo. Es la métrica más representativa de la utilidad operativa real en sistemas UEBA, donde la restricción de investigar solo un porcentaje reducido del total de actividad (e.g., el 0.5 %) impone un límite fijo de K alertas.

- **Rasgo vs. Estado (*Trait vs. State*):**

Distinción fundamental en psicología diferencial. Un **rasgo** es una disposición estable de la personalidad que permanece relativamente constante a lo largo del tiempo y las situaciones (e.g., las dimensiones del *Big Five*). Un **estado** es una condición psicológica transitoria y situacionalmente determinada (e.g., la hostilidad reactiva ante un agravio laboral). La amenaza interna es un fenómeno de **estado**, no de rasgo: el atacante no exfiltra datos porque tenga una puntuación baja en Amabilidad, sino porque atraviesa una fase dinámica de deterioro relacional con la organización. Esta distinción justifica tanto las limitaciones del *Big Five* como la superioridad operativa de métricas dinámicas como el *Z-Score* de sentimiento para la detección temprana.

- **RFT (Teoría de los Marcos Relacionales / *Relational Frame Theory*):**

Marco teórico en psicología del lenguaje y la cognición desarrollado por Hayes y colaboradores (2001), que constituye la base científica de la ACT. La RFT postula que el comportamiento humano complejo está mediado por redes de relaciones simbólicas aprendidas (marcos relacionales) que determinan cómo el individuo interpreta su entorno y regula su conducta. Aplicada al análisis de texto corporativo, la RFT ofrece un marco para ir más allá de la polaridad léxica e inferir cómo el empleado enmarca cognitivamente su relación con la organización: patrones de alienación progresiva (“nosotros vs. ellos”), disonancia entre esfuerzo percibido y reconocimiento recibido, o erosión del compromiso. Estos constructos se corresponden con la fase de ideación del modelo CPIR y representan la evolución natural del módulo NLP del sistema en futuras iteraciones.

- **Tríada Oscura (*Dark Triad*):**

Constructo psicológico que agrupa tres rasgos de personalidad subclínicos (Narcisismo, Maquiavelismo y Psicopatía) identificados por Paulhus y Williams (2002) como predictores de comportamiento antisocial en contextos normativos. A diferencia de los trastornos clínicos formales, los rasgos de la Tríada Oscura se distribuyen en la población general de forma dimensional y son especialmente relevantes en perfiles de delincuencia corporativa: el individuo con puntuaciones elevadas tiende a la manipulación instrumental, la ausencia de empatía y la disposición a transgredir normas cuando el beneficio percibido supera el riesgo de detección. Constituye el marco psicométrico de referencia en criminología forense para el perfil del atacante interno motivado por ego o venganza (categorías del modelo MICE).

- ***Tripwire (Cable Trampa):***

Metáfora operativa empleada en ciberseguridad y en este proyecto para describir la función del sistema de detección: un mecanismo de activación temprana que detecta la anomalía conductual y desencadena una respuesta humana, sin ejecutar ninguna acción autónoma sobre el individuo. La imagen es deliberada: el *tripwire* no atrapa ni sanciona, simplemente alerta de que algo ha cruzado un umbral que merece atención. En el contexto del Marco de Triage Conductual propuesto, la respuesta desencadenada es siempre una derivación preventiva a bienestar organizacional, nunca una acción punitiva automatizada.

- ***SHAP (SHapley Additive exPlanations):***

Método basado en la Teoría de Juegos cooperativos (Shapley, 1953) utilizado para aumentar la transparencia de los modelos de *Machine Learning*, asignando a cada variable su contribución exacta y marginal a la predicción final. Garantiza tres propiedades matemáticas esenciales para contextos forenses: eficiencia (las contribuciones suman exactamente la diferencia entre la predicción individual y el valor base), simetría y linealidad. Permite auditar las decisiones del modelo variable a variable, tanto a nivel local (caso individual) como global (comportamiento sistemático del modelo).

- ***SIEM (Security Information and Event Management):***

Plataforma tecnológica que centraliza la recopilación, correlación y análisis de eventos de seguridad en tiempo real procedentes de múltiples fuentes de una infraestructura de TI (servidores, *firewalls*, *endpoints*, etc.). Opera mediante reglas estáticas y heurísticas predefinidas. Su principal limitación frente al atacante interno es la incapacidad de detectar comportamientos anómalos que no violen ninguna regla preestablecida, al utilizar credenciales legítimas.

- ***Sobreajuste (Overfitting):***

Fenómeno por el cual un modelo de aprendizaje automático aprende con excesiva especificidad las particularidades del conjunto de entrenamiento, incluyendo el ruido aleatorio, perdiendo su capacidad de generalización a datos nuevos no vistos. En el Autoencoder desarrollado en este proyecto se mitigó mediante capas *Dropout* y monitorización de la pérdida de validación.

- ***UEBA (User and Entity Behavior Analytics):***

Paradigma de ciberseguridad que abandona la búsqueda de “firmas” de amenazas conocidas en favor de la creación de una línea base dinámica del comportamiento normal de cada usuario y entidad (dispositivo, servidor, etc.). Las desviaciones estadísticamente significativas respecto a esa línea base individual generan alertas de riesgo, independientemente de si el comportamiento viola alguna regla técnica establecida.

- **VADER (*Valence Aware Dictionary and sEntiment Reasoner*):**

Herramienta de análisis de sentimiento basada en un léxico de reglas diseñada específicamente para texto en redes sociales y comunicaciones informales en inglés. Proporciona cuatro puntuaciones: *positive*, *negative*, *neutral* y *compound* (índice normalizado entre -1 y +1 que resume la valencia global del texto). Su principal ventaja es la ausencia de necesidad de entrenamiento supervisado, lo que la hace aplicable en contextos donde no se dispone de datos etiquetados.

- **Validez Ecológica:**

Criterio metodológico que evalúa el grado en que los resultados obtenidos en un entorno controlado o simulado son representativos y generalizables a los comportamientos y situaciones de la vida real. No es un atributo binario sino un continuo: cuanto más artificiales son las condiciones de producción de los datos, menor es la confianza en que las relaciones estadísticas detectadas reflejen dinámicas genuinas del comportamiento humano fuera del entorno simulado. En este proyecto, la validez ecológica del *dataset* CERT r4.2 está comprometida por el sistema de mapeado técnico-psicométrico empleado en su construcción, lo que limita la generalización de los resultados a escenarios reales y orienta el trabajo futuro hacia la validación sobre datos organizacionales auténticos.

- **Z-Score (Puntuación Estándar):**

Medida estadística que indica cuántas desviaciones estándar un dato específico se encuentra por encima o por debajo de la media de su grupo de referencia. En este proyecto se aplica de forma **intrasujeto**: el *Z-Score* de sentimiento de un usuario compara su estado afectivo actual con su propia media histórica, no con la media de la organización. Esta implementación personalizada evita la comparación interpersonal y garantiza que el sistema detecte la *deriva individual*, no la diferencia respecto a un estándar colectivo.

Capítulo 8

Bibliografía

- Abadi, M., Agarwal, A., Barham, P., Brevdo, E., Chen, Z., Citro, C., Corrado, G., Davis, A., Dean, J., Devin, M., Ghemawat, S., Goodfellow, I., Harp, A., Irving, G., Isard, M., Jia, Y., Jozefowicz, R., Kaiser, L., Kudlur, M., ... Zheng, X. (2015). *TensorFlow: Large-Scale Machine Learning on Heterogeneous Systems*. <https://www.tensorflow.org/>
- Abiola, O., Abayomi-Alli, A., Tale, O. A., Misra, S., & Abayomi-Alli, O. (2023). Sentiment analysis of COVID-19 tweets from selected hashtags in Nigeria using VADER and TextBlob analyser. *Journal of Electrical Systems and Information Technology*, 10(1), 5. <https://doi.org/10.1186/s43067-023-00070-9>
- Al-Mhiqani, M. N., Ahmad, R., Zainal Abidin, Z., Yassin, W., Hassan, A., Abdulkareem, K. H., Ali, N. S., & Yunus, Z. (2020). A review of insider threat detection: Classification, machine learning techniques, datasets, open challenges, and recommendations. *Applied Sciences*, 10(15), 5208. <https://doi.org/10.3390/app10155208>
- American Psychological Association (APA). (2017). *Ethical Principles of Psychologists and Code of Conduct*. <https://www.apa.org/ethics/code/>
- Asad Hasan. (s. f.). *Processed_CERT_Insider_Threat_dataset_using-CTI-framework* [Dataset]. IEEE DataPort. <https://doi.org/10.21227/TGSH-4409>
- Ashton, M. C., & Lee, K. (2007). Empirical, theoretical, and practical advantages of the HEXACO model of personality structure. *Personality and Social Psychology Review*, 11(2), 150–166. <https://doi.org/10.1177/1088868306294907>
- Barrera Mora, A. (2026). *Behavioral and Psychometric Feature Matrix for Insider Threat Detection (Derived from CERT r4.2) (1.0.0)* [Data set]. Zenodo. <https://doi.org/10.5281/zenodo.19435851>
- Basu, S., Victoria Chua, Y. H., Wah Lee, M., Lim, W. G., Maszczyk, T., Guo, Z., & Dauwels, J. (2018). Towards a data-driven behavioral approach to prediction of insider-threat. *2018 IEEE International Conference on Big Data (Big Data)*, 4994–5001. <https://doi.org/10.1109/BigData.2018.8622529>

- Bell, A. J., Rogers, M. B., & Pearce, J. M. (2019). The insider threat: Behavioral indicators and factors influencing likelihood of intervention. *International Journal of Critical Infrastructure Protection*, 24, 166–176. <https://doi.org/10.1016/j.ijcip.2018.12.001>
- BobSulli. (2023). Cost Of Insider Risks Global Report 2023. *Ponemon-Sullivan Privacy Report*. <https://ponemonsullivanreport.com/2023/10/cost-of-insider-risks-global-report->
- Bronfenbrenner, U. (1977). Toward an experimental ecology of human development. *American psychologist*, 32(7), 513.
- California Consumer Privacy Act of 2018 (CCPA), Cal. Civ. Code § 1798.100 et seq. <https://oag.ca.gov/privacy/ccpa>
- Cressey, D. R. (1973). *Other people's money: A study in the social psychology of embezzlement*. Patterson Smith.
- European Federation of Psychologists' Associations (EFPA). (2005). *Meta-code of Ethics*. <https://www.efpa.eu/sites/default/files/2023-04/meta-code-of-ethics.pdf>
- Fayyad, D. (2025). Measuring the human risk factor: Developing predictive models for insider threat detection using behavioral analytics. *International Journal of Humanities and Information Technology*, 7(4), 29–40.
- Glasser, J., & Lindauer, B. (2013). Bridging the gap: A pragmatic approach to generating insider threat data. *IEEE Security and Privacy Workshops*, 98–104. <https://doi.org/10.1109/SPW.2013.37>
- Greitzer, F. L., & Frincke, D. A. (2010). Combining traditional cyber security audit data with psychosocial data: Towards predictive modeling for insider threat mitigation. En *Insider threats in cyber security* (pp. 85–113). Springer.
- Greitzer, F. L., Kangas, L. J., Noonan, C. F., Brown, C. R., & Ferryman, T. (2013). Psychosocial modeling of insider threat risk based on behavioral and word use analysis. *e-Service Journal*, 9(1), 106–138.
- Greitzer, F. L., Kangas, L. J., Noonan, C. F., Dalton, A. C., & Hohimer, R. E. (2012). Identifying at-risk employees: Modeling psychosocial precursors of potential insider threats. *Proceedings of the 45th Hawaii International Conference on System Sciences*, 2392–2401. <https://doi.org/10.1109/HICSS.2012.309>
- Hayes, S. C., Barnes-Holmes, D., & Roche, B. (Eds.). (2001). *Relational frame theory: A post-Skinnerian account of human language and cognition*. Kluwer Academic/Plenum Publishers.
- Hayes, S. C., Strosahl, K. D., & Wilson, K. G. (2001). *Acceptance and Commitment Therapy: An experiential approach to behavior change*. Guilford Press.
- Haq, M. A., & Alshehri, M. (2022). Insider threat detection based on NLP word embedding and machine learning. *Intelligent Automation and Soft Computing*, 33, 619–635. <https://doi.org/10.32604/iasc.2022.021430>

- Hutto, C., & Gilbert, E. (2014). VADER: A parsimonious rule-based model for sentiment analysis of social media text. *Proceedings of the 8th International AAAI Conference on Weblogs and Social Media (ICWSM-14)*, 8(1), 216–225.
- Idensohn, C. J., & Flowerday, S. (2024). Malicious insider behaviour in cybersecurity informed by the Fraud Triangle. *Journal of Information Systems Security*, 22.
- Jiang, W., Tian, Y., Liu, W., & Liu, W. (2018). An insider threat detection method based on user behavior analysis. En *International Conference on Security, Privacy and Anonymity in Computation, Communication and Storage* (pp. 421–431). Springer. https://doi.org/10.1007/978-3-030-00828-4_43
- Khan, M. Z. A., & Arshad, J. (2022). Anomaly detection and enterprise security using user and entity behavior analytics (UEBA). *IEEE*, 1–9.
- Kim, J., Park, M., Kim, H., Cho, S., & Kang, P. (2019). Insider threat detection based on user behavior modeling and anomaly detection algorithms. *Applied Sciences*, 9(19), 4018. <https://doi.org/10.3390/app9194018>
- Krishnaraja, K., & Moorthy, G. K. (2023). Big 5 personality traits and machine learning: A combined approach for classifying malicious insiders. *Journal of Technical Education*, 20, 20.
- Le, D. C., Zincir-Heywood, N., & Heywood, M. I. (2020). Analyzing data granularity levels for insider threat detection using machine learning. *IEEE Transactions on Network and Service Management*, 17(1), 30–44. <https://doi.org/10.1109/TNSM.2020.2967721>
- Lindauer, B., Glässer, J., Rosen, M., Wallnau, K., & Moore, A. (2014). *Insider Threat Test Dataset* (CERT r4.2) [Dataset]. Software Engineering Institute, Carnegie Mellon University. <https://www.sei.cmu.edu/library/insider-threat-test-dataset/>
- Liu, F. T., Ting, K. M., & Zhou, Z. H. (2008). Isolation Forest. *2008 Eighth IEEE International Conference on Data Mining*, 413–422. <https://doi.org/10.1109/ICDM.2008.17>
- Lundberg, S. M., & Lee, S. I. (2017). A unified approach to interpreting model predictions. *Advances in Neural Information Processing Systems*, 30, 4765–4774.
- McCrae, R. R., & Costa, P. T. (1987). Validation of the five-factor model of personality across instruments and observers. *Journal of Personality and Social Psychology*, 52(1), 81–90. <https://doi.org/10.1037/0022-3514.52.1.81>
- Mittal, A., & Garg, U. (2022). A proposed approach to analyze insider threat detection using emails. *2022 International Conference on Computer Communication and Informatics (ICCCI)*, 1–6.
- Mladenovic, D., Antonijevic, M., Jovanovic, L., Simic, V., Zivkovic, M., Bacanin, N., Zivkovic, T., & Perisic, J. (2024). Sentiment classification for insider threat identification using metaheuristic optimized machine learning classifiers. *Scientific Reports*, 14, 25731. <https://doi.org/10.1038/s41598-024-77240-w>

- Mosca, E., Szigeti, F., Tragianni, S., Gallagher, D., & Groh, G. (2022). SHAP-based explanation methods: A review for NLP interpretability. *Proceedings of the 29th International Conference on Computational Linguistics*, 4593–4603.
- Nanamou, N. K., Neal, C., Boulahia-Cuppens, N., Cuppens, F., & Bkakria, A. (2024). From traits to threats: Learning risk indicators of malicious insider using psychometric data. https://doi.org/10.1007/978-3-031-80020-7_10
- Ohu, F., & Jones, L. A. (2025). Predictive behavioral risk intelligence: An AI framework for insider threat detection based on cognitive and psychological indicators. *RAIS Journal for Social Sciences*, 9(2), 108–132.
- Paulhus, D. L., & Williams, K. M. (2002). The Dark Triad of personality: Narcissism, Machiavellianism, and psychopathy. *Journal of Research in Personality*, 36(6), 556–568. [https://doi.org/10.1016/S0092-6566\(02\)00505-6](https://doi.org/10.1016/S0092-6566(02)00505-6)
- Paxton-Fear, K. (2021). *Understanding insider threats using natural language processing* [Tesis doctoral]. University of Oxford.
- Pedregosa, F., Varoquaux, G., Gramfort, A., Michel, V., Thirion, B., Grisel, O., Blondel, M., Prettenhofer, P., Weiss, R., Dubourg, V., Vanderplas, J., Passos, A., Cournapeau, D., Brucher, M., Perrot, M., & Duchesnay, É. (2011). Scikit-learn: Machine learning in Python. *Journal of Machine Learning Research*, 12, 2825–2830.
- Ponce-Bobadilla, A. V., Schmitt, V., Maier, C. S., Mensing, S., & Stodtman, S. (2024). Practical guide to SHAP analysis: Explaining supervised machine learning model predictions in drug development. *Clinical and Translational Science*, 17(11), e70056. <https://doi.org/10.1111/cts.70056>
- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos). *Diario Oficial de la Unión Europea*, L 119, 1-88.
- Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas sobre inteligencia artificial (Ley de Inteligencia Artificial). *Diario Oficial de la Unión Europea*, L 2024/1689.
- Schuchter, A., & Levi, M. (2016). The Fraud Triangle revisited. *Security Journal*, 29, 107–121. <https://doi.org/10.1057/sj.2013.1>
- Shaw, E., & Sellers, L. (2015). Application of the critical-path method to evaluate insider risks. *Studies in Intelligence*, 59(2).
- Singh, M., Mehtre, B. M., & Sangeetha, S. (2022). User behavior based insider threat detection using a multi fuzzy classifier. *Multimedia Tools and Applications*, 81(16), 22953–22983. <https://doi.org/10.1007/s11042-022-12173-y>

- Soh, C., Yu, S., Narayanan, A., Duraisamy, S., & Chen, L. (2019). Employee profiling via aspect-based sentiment and network for insider threats detection. *Expert Systems with Applications*, 135, 351–361. <https://doi.org/10.1016/j.eswa.2019.05.043>
- Sollod, R. N., Wilson, J. P., & Monte, C. F. (2009). *Teorías de la personalidad: Debajo de la máscara* (1.^a ed. en español). McGraw-Hill.
- Taylor, M., Haggerty, J., Gresty, D., Almond, P., & Berry, T. (2014). Forensic investigation of social networking applications. *Network Security*, 2014(11), 9–16.
- Terrill, D., Trichas, M., & Bowden, D. (2024). “To betray, you must first belong”: Psychological pathways to insider threat and radicalisation. *Journal of Military and Strategic Studies*, 23(2).
- Tuor, A., Kaplan, S., Hutchinson, B., Nichols, N., & Robinson, S. (2017). Deep learning for unsupervised insider threat detection in structured cybersecurity data streams. *AI for Cyber Security Workshop (AAAI)*, 224–231.
- Van den Broeck, G., Lykov, A., Schleich, M., & Suciú, D. (2022). On the tractability of SHAP explanations. *Journal of Artificial Intelligence Research*, 74, 851–886.
- Wei, Z., Rauf, U., & Mohsen, F. (2024). E-Watcher: Insider threat monitoring and detection for enhanced security. *Annals of Telecommunications*, 79(11), 819–831. <https://doi.org/10.1007/s12243-024-01023-7>
- Yuan, S., & Wu, X. (2021). Deep learning for insider threat detection: Review, challenges and opportunities. *Computers & Security*, 104, 102221. <https://doi.org/10.1016/j.cose.2021.102221>